

DATA PRIVACY

Principles and Practice

Nataraj Venkataramanan
Ashwin Shriram



CRC Press
Taylor & Francis Group

A CHAPMAN & HALL BOOK

DATA PRIVACY

Principles and Practice

DATA PRIVACY

Principles and Practice

Nataraj Venkataramanan
Ashwin Shriram



CRC Press
Taylor & Francis Group
6000 Broken Sound Parkway NW, Suite 300
Boca Raton, FL 33487-2742

© 2017 by Taylor & Francis Group, LLC
CRC Press is an imprint of Taylor & Francis Group, an Informa business

No claim to original U.S. Government works

Printed on acid-free paper
Version Date: 20160628

International Standard Book Number-13: 978-1-4987-2104-2 (Hardback)

This book contains information obtained from authentic and highly regarded sources. Reasonable efforts have been made to publish reliable data and information, but the author and publisher cannot assume responsibility for the validity of all materials or the consequences of their use. The authors and publishers have attempted to trace the copyright holders of all material reproduced in this publication and apologize to copyright holders if permission to publish in this form has not been obtained. If any copyright material has not been acknowledged please write and let us know so we may rectify in any future reprint.

Except as permitted under U.S. Copyright Law, no part of this book may be reprinted, reproduced, transmitted, or utilized in any form by any electronic, mechanical, or other means, now known or hereafter invented, including photocopying, microfilming, and recording, or in any information storage or retrieval system, without written permission from the publishers.

For permission to photocopy or use material electronically from this work, please access www.copyright.com ([http://www.copyright.com/](http://www.copyright.com)) or contact the Copyright Clearance Center, Inc. (CCC), 222 Rosewood Drive, Danvers, MA 01923, 978-750-8400. CCC is a not-for-profit organization that provides licenses and registration for a variety of users. For organizations that have been granted a photocopy license by the CCC, a separate system of payment has been arranged.

Trademark Notice: Product or corporate names may be trademarks or registered trademarks, and are used only for identification and explanation without intent to infringe.

Library of Congress Cataloging-in-Publication Data

Names: Venkataramanan, Nataraj, author.
Title: Data privacy : principles and practice / Nataraj Venkataramanan and Ashwin Shriram.
Description: Boca Raton, FL : CRC Press, 2017. | Includes bibliographical references and index.
Identifiers: LCCN 2016009691 | ISBN 9781498721042 (alk. paper)
Subjects: LCSH: Data protection. | Management information systems--Security measures. | Computer networks--Security measures. | Privacy, Right of. | Customer relations.
Classification: LCC HF5548.37 .V46 2017 | DDC 005.8--dc23
LC record available at <https://lcn.loc.gov/2016009691>

Visit the Taylor & Francis Web site at
<http://www.taylorandfrancis.com>

and the CRC Press Web site at
<http://www.crcpress.com>

In memory of my parents

V. Sulochana and E. Venkataramanan

and my Guru

Sri Chandrasekharendra Saraswathi

Nataraj Venkataramanan

Seeking God's blessings, I dedicate this book to my wonderful parents, my lovely wife, and daughter, who have sacrificed so much to make this happen.

Ashwin Shriram

Contents

Preface

Acknowledgments

Authors

List of Abbreviations

1. Introduction to Data Privacy

1.1 Introduction

1.2 What Is Data Privacy and Why Is It Important?

1.2.1 Protecting Sensitive Data

1.2.2 Privacy and Anonymity: Two Sides of the Same Coin

1.3 Use Cases: Need for Sharing Data

1.3.1 Data Mining and Analysis

1.3.2 Software Application Testing

1.3.3 Business Operations

1.4 Methods of Protecting Data

1.5 Importance of Balancing Data Privacy and Utility

1.5.1 Measuring Privacy of Anonymized Data

1.5.2 Measuring Utility of Anonymized Data

1.6 Introduction to Anonymization Design Principles

1.7 Nature of Data in the Enterprise

1.7.1 Multidimensional Data

1.7.1.1 Challenges in Privacy Preservation of Multidimensional Data

1.7.2 Transaction Data

1.7.2.1 Challenges in Privacy Preservation of Transaction Data

1.7.3 Longitudinal Data

1.7.3.1 Challenges in Anonymizing Longitudinal Data

1.7.4 Graph Data

1.7.4.1 Challenges in Anonymizing Graph Data

1.7.5 Time Series Data

1.7.5.1 Challenges in Privacy Preservation of Time Series Data

References

2. Static Data Anonymization Part I: Multidimensional Data

2.1 Introduction

2.2 Classification of Privacy Preserving Methods

2.3 Classification of Data in a Multidimensional Data Set

2.3.1 Protecting Explicit Identifiers

2.3.2 Protecting Quasi-Identifiers

2.3.2.1 Challenges in Protecting QI

2.3.3 Protecting Sensitive Data (SD)

2.4 Group-Based Anonymization

2.4.1 k-Anonymity

2.4.1.1 Why k-Anonymization?

2.4.1.2 How to Generalize Data?

2.4.1.3 Implementing k-Anonymization

2.4.1.4 How Do You Select the Value of k?

2.4.1.5 Challenges in Implementing k-Anonymization

2.4.1.6 What Are the Drawbacks of k-Anonymization?

2.4.2 *l*-Diversity

2.4.2.1 Drawbacks of *l*-Diversity

2.4.3 t-Closeness

2.4.3.1 What Is t-Closeness?

2.4.4 Algorithm Comparison

2.5 Summary

References

3. Static Data Anonymization Part II: Complex Data Structures

3.1 Introduction

3.2 Privacy Preserving Graph Data

- 3.2.1 Structure of Graph Data
- 3.2.2 Privacy Model for Graph Data
 - 3.2.2.1 Identity Protection
 - 3.2.2.2 Content Protection
 - 3.2.2.3 Link Protection
 - 3.2.2.4 Graph Metrics
- 3.3 Privacy Preserving Time Series Data
 - 3.3.1 Challenges in Privacy Preservation of Time Series Data
 - 3.3.1.1 High Dimensionality
 - 3.3.1.2 Background Knowledge of the Adversary
 - 3.3.1.3 Pattern Preservation
 - 3.3.1.4 Preservation of Statistical Properties
 - 3.3.1.5 Preservation of Frequency-Domain Properties
 - 3.3.2 Time Series Data Protection Methods
 - 3.3.2.1 Additive Random Noise
 - 3.3.2.2 Perturbation of Time Series Data Using Generalization: k-Anonymization
- 3.4 Privacy Preservation of Longitudinal Data
 - 3.4.1 Characteristics of Longitudinal Data
 - 3.4.1.1 Challenges in Anonymizing Longitudinal Data
- 3.5 Privacy Preservation of Transaction Data
- 3.6 Summary
- References

4. Static Data Anonymization Part III: Threats to Anonymized Data

- 4.1 Threats to Anonymized Data
- 4.2 Threats to Data Structures
 - 4.2.1 Multidimensional Data
 - 4.2.2 Longitudinal Data
 - 4.2.3 Graph Data
 - 4.2.4 Time Series Data
 - 4.2.5 Transaction Data

4.3 Threats by Anonymization Techniques

4.3.1 Randomization (Additive)

4.3.2 k-Anonymization

4.3.3 l-Diversity

4.3.4 t-Closeness

4.4 Summary

References

5. Privacy Preserving Data Mining

5.1 Introduction

5.2 Data Mining: Key Functional Areas of Multidimensional Data

5.2.1 Association Rule Mining

5.2.1.1 Privacy Preserving of Association Rule Mining: Random Perturbation

5.2.2 Clustering

5.2.2.1 A Brief Survey of Privacy Preserving Clustering Algorithms

5.3 Summary

References

6. Privacy Preserving Test Data Manufacturing

6.1 Introduction

6.2 Related Work

6.3 Test Data Fundamentals

6.3.1 Testing

6.3.1.1 Functional Testing: System and Integration Testing

6.3.1.2 Nonfunctional Testing

6.3.2 Test Data

6.3.2.1 Test Data and Reliability

6.3.2.2 How Are Test Data Created Today?

6.3.3 A Note on Subsets

6.4 Utility of Test Data: Test Coverage

6.4.1 Privacy versus Utility

- 6.4.2 Outliers
- 6.4.3 Measuring Test Coverage against Privacy
- 6.5 Privacy Preservation of Test Data
 - 6.5.1 Protecting Explicit Identifiers
 - 6.5.1.1 Essentials of Protecting EI
 - 6.5.1.2 What Do Tools Offer?
 - 6.5.1.3 How Do Masking Techniques Affect Testing?
 - 6.5.2 Protecting Quasi-Identifiers
 - 6.5.2.1 Essentials of Protecting QI
 - 6.5.2.2 Tool Offerings to Anonymize QI
 - 6.5.2.3 How Does QI Anonymization Affect Test Coverage?
 - 6.5.3 Protecting Sensitive Data (SD)
- 6.6 Quality of Test Data
 - 6.6.1 Lines of Code Covered
 - 6.6.2 Query Ability
 - 6.6.3 Time for Testing
 - 6.6.3.1 Test Completion Criteria
 - 6.6.3.2 Time Factor
 - 6.6.4 Defect Detection
- 6.7 Anonymization Design for PPTDM
- 6.8 Insufficiencies of Anonymized Test Data
 - 6.8.1 Negative Testing
 - 6.8.2 Sensitive Domains
 - 6.8.3 Nonfunctional Testing
 - 6.8.4 Regression Testing
 - 6.8.5 Trust Deficit
- 6.9 Summary

References

7. Synthetic Data Generation

7.1 Introduction

- 7.2 Related Work
- 7.3 Synthetic Data and Their Use
- 7.4 Privacy and Utility in Synthetic Data
 - 7.4.1 Explicit Identifiers
 - 7.4.1.1 Privacy
 - 7.4.1.2 Utility
 - 7.4.1.3 Generation Algorithms
 - 7.4.2 Quasi-Identifiers
 - 7.4.2.1 Privacy
 - 7.4.2.2 Utility
 - 7.4.2.3 Generation Algorithms
 - 7.4.3 Sensitive Data
 - 7.4.3.1 Privacy
 - 7.4.3.2 Utility
- 7.5 How Safe Are Synthetic Data?
 - 7.5.1 Testing
 - 7.5.1.1 Error and Exception Data
 - 7.5.1.2 Scaling
 - 7.5.1.3 Regression Testing
 - 7.5.2 Data Mining
 - 7.5.3 Public Data
- 7.6 Summary
- References

8. Dynamic Data Protection: Tokenization

- 8.1 Introduction
- 8.2 Revisiting the Definitions of Anonymization and Privacy
- 8.3 Understanding Tokenization
 - 8.3.1 Dependent Tokenization
 - 8.3.2 Independent Tokenization
- 8.4 Use Cases for Dynamic Data Protection

- 8.4.1 Business Operations
- 8.4.2 Ad Hoc Reports for Regulatory Compliance
- 8.5 Benefits of Tokenization Compared to Other Methods
- 8.6 Components for Tokenization
 - 8.6.1 Data Store
 - 8.6.2 Tokenization Server
- 8.7 Summary
- Reference

9. Privacy Regulations

- 9.1 Introduction
- 9.2 UK Data Protection Act 1998
 - 9.2.1 Definitions
 - 9.2.2 Problems in DPA
- 9.3 Federal Act of Data Protection of Switzerland 1992
 - 9.3.1 Storing Patients' Records in the Cloud
 - 9.3.2 Health Questionnaires for Job Applicants
 - 9.3.3 Transferring Pseudonymized Bank Customer Data Outside Switzerland
- 9.4 Payment Card Industry Data Security Standard (PCI DSS)
- 9.5 The Health Insurance Portability and Accountability Act of 1996 (HIPAA)
 - 9.5.1 Effects of Protection
 - 9.5.2 Anonymization Considerations
 - 9.5.2.1 Record Owner
 - 9.5.2.2 Business Associate
 - 9.5.3 Anonymization Design for HIPAA
 - 9.5.4 Notes on EIs, QIs, and SD
 - 9.5.4.1 Explicit Identifiers
 - 9.5.4.2 Quasi-Identifiers
 - 9.5.4.3 Sensitive Data
- 9.6 Anonymization Design Checklist
- 9.7 Summary

9.8 Points to Ponder

References

Appendix A: Anonymization Design Principles for Multidimensional Data

Appendix B: PPTDM Manifesto

Index

Preface

The ubiquity of computers and smart devices on the Internet has led to vast amounts of data being collected from users, shared, and analyzed. Most of these data are collected from customers by enterprises dealing with banking, insurance, healthcare, financial services, retail, e-commerce, manufacturing, and social networks. These data consist of transactional data, search data, and health and financial data, almost always including a lot of personal data. On the one hand, these data are considered valuable for the enterprise as they can be used for a variety of purposes, such as knowledge discovery, software application development, and application testing. At the same time, these data are considered to be sensitive as they contain their customers' personal information. Therefore, sharing, offshoring, or outsourcing of such data for purposes like data mining or application testing should ensure that customers' personal information is not compromised in any way. Many countries have stringent data protection acts, such as the Health Insurance Portability and Accountability Act of 1996 (HIPAA) in the United States, the EU Data Protection Act, and the Swiss Data Protection Act, which mandate high standards of data privacy. In this context, data privacy, which pertains to protecting the identity of the customers, is high priority for all enterprises as any data privacy loss would result in legal issues with hefty fines, erosion of customer confidence, and customer attrition. To this effect, data privacy as a subject of study is being introduced in some universities at the postgraduate level. Various certifications like PrivacyTrust and CIPP also exist, which endorse an individual's knowledge of privacy laws.

Data privacy as a subject of study and practice is relatively young; in particular, many of the techniques used for data protection are still evolving. Currently, many companies are adopting these data privacy techniques as they try to leverage the opportunities provided by offshoring and outsourcing while at the same time complying with regulatory requirements. This book provides a comprehensive guidance on the implementation of many of the data privacy techniques in a variety of applications. An enterprise's data architecture consists of a wide variety of data structures like multidimensional data, also known as relational data, which are the most widely used data structure, and complex data structures like transaction data, longitudinal data, time series data, graph data, and spatiotemporal data. Multidimensional data are simple in structure, and a rich set of anonymization algorithms are in use currently for such data, but anonymization techniques for other complex data structures are still evolving. [Chapters 2 through 4](#) attempt to provide a detailed coverage on the various anonymization approaches for both multidimensional and complex data structures. [Chapters 5 and 6](#) focus on applications such as privacy preserving data mining and privacy preserving test data management. [Chapter 7](#) focuses on synthetic data that are

used as an alternative to anonymization. There is a requirement for protection of data during run-time—dynamic data protection—which is covered in [Chapter 8](#). Here, the techniques of one-way and two-way tokenization are covered. [Appendix A](#) provides a detailed set of anonymization design principles, which serve as guidelines to the practitioner. The salient features of this book are

- Static data anonymization techniques for multidimensional data
- Clear-cut guidelines on anonymization design
- Analysis of anonymization algorithms
- Static data anonymization techniques for complex data structures like transaction, longitudinal, time series, and graph data
- Emphasis on privacy versus utility in the techniques
- Applications of anonymization techniques on a variety of domains like privacy preserving data mining and privacy preserving test data management
- Use of synthetic data in place of anonymized data
- Use of tokenization algorithms for dynamic data protection

Acknowledgments

Writing a book is never easy. It requires hard work, research, collaboration, and support from various quarters. Both of us thank our management at HCL Technologies Ltd. for providing a wonderful environment conducive to learning and innovation. We thank our colleague, Harikrishnan Janardhanan, for his selfless support during this endeavor.

We thank N. Krishna and Dr. K. R. Gunasekar of the Indian Institute of Science, Bangalore, India, for helping us with our research in this field. We sincerely thank Aastha Sharma and the members of the editorial group at CRC Press/Taylor & Francis Group for their support in completing this work.

Writing a book is hard and one needs to spend a lot of time on it. This reduces the amount of time one gets to spend with one's family. Nataraj owes special thanks to his wife, Kalyani, and his two sons, Balaji and Srihari, for providing constant encouragement throughout this period. Ashwin thanks his parents for their blessings and support. He appreciates his wife, Deepa, for taking over the entire responsibility of raising their little daughter, Srishti, during this time.

Finally, we collectively thank God for giving us the courage, perseverance, and diligence to contribute to an area that we firmly believe is extremely important in today's world.

Authors

Nataraj Venkataramanan is currently an associate vice president at HCL Technologies Ltd., India. He has previously worked in some of India's major information technology (IT) companies and has over two decades of experience in computing. He has worked across different domains such as banking, financial services, insurance, government, oil and gas, retail, and manufacturing. His main research interests are in large-scale software architecture, quality attributes of software architecture, data privacy, privacy preserving data mining, data analytics, pattern recognition, and learning systems. He has published refereed technical papers in journals and conferences. He is a member of IEEE and ACM. Nataraj can be reached at nataraj.venkataramanan@gmail.com.

Ashwin Shriram works for HCL Technologies as a solution architect. As an engineer in computer science, he has a strong technical background in data management. At HCL, Ashwin is a senior member of the Test Data Management Center of Excellence. His current research interests include data privacy, data analytics, pattern recognition, and big data privacy. Prior to joining HCL, he was working in the United States for customers in public as well as in private sectors. Ashwin can be reached at ashwin.shriram@gmail.com.

List of Abbreviations

AG-TS	Attribute generalization–tuple suppression
API	Application programming interface
BPO	Business process outsourcing
CCN	Credit card number
CIPP	Certified information privacy professional
CM	Classification metric
DGH	Domain generalization hierarchy
DMV	Department of motor vehicles
DOB	Date of birth
DPA	Data Protection Act (UK)
EC	Equivalence class
ECG	Electrocardiogram
EI	Explicit identifier
FADP	Federal Act on Data Protection
FERPA	Family Educational Rights and Privacy Act
FIPPA	Freedom of Information and Protection of Privacy Act
HIPAA	Health Insurance Portability and Accountability Act
IDAS	Information discovery and analysis systems
IDSG	Information discovery scenario generator
IOT	Internet of things
ISI	International Statistical Institute
LDAP	Lightweight Directory Access Protocol
LM	Information loss metric
LOC	Lines of code
MBA	Market basket analysis
MTBF	Mean time between failures
MTTR	Mean time to recovery
NFR	Nonfunctional requirements
NSD	Nonsensitive data
ODS	Operational data store
OECD	Organization for Economic Cooperation and Development
PAN	Permanent account number
PCI	Payment card industry

PCI DSS	Payment Card Interface Data Security Standard
PHI	Protected health information
PII	Personally identifiable information
PPDM	Privacy preserving data mining
PPTDM	Privacy preserving test data manufacturing
QI	Quasi-identifier
SD	Sensitive data
SDC	Statistical disclosure control
SDDL	Synthetic data description language
SDG	Synthetic data generation
SDLC	Systems development life cycle
SMC/MPC	Secure multiparty computation/multiparty computation
SSN	Social security number
TDM	Test data manufacturing/test data management
TSG	Threat stream generator
VIN	Vehicle identification number
ZKP	Zero-knowledge proof

Introduction to Data Privacy

1.1 Introduction

Organizations dealing with banking, insurance, retail, healthcare, and manufacturing across the globe collect large amounts of data about their customers. This is a valuable asset to the organizations as these data can be mined to extract a lot of insights about their customers. For example, mining these data can throw light on customers' spending/buying, credit card usage, and investment patterns and health issues, to name a few. This information is used by companies to provide value-added services to their customers, which in turn results in higher revenue and profit. But these data might contain customers' personal identification information, and when in the hands of a data snooper, they can be exploited.

Large companies across the globe outsource their IT and business process work to service providers in countries like India, China, Brazil, etc. The outsourced work may involve application maintenance and development, testing, data mining/analysis, statistical analysis, etc. Business applications contain sensitive information, such as personal or financial and health-related data. Sharing such data can potentially violate individual privacy and lead to financial loss to the company. Serious concerns have been expressed by general public about exposing person-specific information. The issue of data leakage, either intentional or accidental exposure of sensitive information, is becoming a major security issue.

An IDC survey [19] claims that data leakage is the number one threat, ranked higher than viruses, Trojan horses, and worms. To address the privacy of an individual's data, governments across the globe have mandated regulations that companies have to adhere to: HIPAA (Health Insurance Portability and Accountability Act) in the United States, FIPPA (Freedom of Information and Protection of Privacy Act) in Canada, Sarbanes–Oxley Act, Video Privacy Protection, U.S. Declaration of Human Rights, and the EU's Data Protection Directive are just a few examples. Companies need to look into methods and tools to anonymize sensitive data. Data anonymization techniques have been the subject of intense investigation in recent years for many kinds of structured data, including tabular, transactional data, and graph data.

In [Chapter 2](#), Static Data Anonymization, we discuss relational data, also known as

multidimensional data, which are the most widely found data structure in enterprises currently. This chapter focuses on privacy preservation methods for multidimensional data. Multidimensional data are simple in structure, and a rich set of data protection algorithms, such as randomization, generalization, k-anonymization, *l*-diversity, and t-closeness, is described.

Anonymization techniques for multidimensional data are simple in structure and very commonly found across enterprises. Apart from multidimensional data, other types of data structures, such as graph, longitudinal data, sparse high-dimensional transaction data, time series data, spatiotemporal data, semistructured XML data, and big data, are also present across enterprises. These data structures are complex, contain sensitive customer information, and should therefore be protected. There are unique challenges in designing anonymization techniques for these complex data structures, though. Anonymization techniques used for the protection of multidimensional data are not directly applicable to these complex data structures. [Chapter 3](#) discusses some of the anonymization techniques for complex data structures.

Any anonymization design is a function of many inputs. One of the important inputs is, “who are we protecting these data from?” The answer builds a profile of adversaries who are expected to attack the data. [Chapter 4](#) explains various profiles of adversaries, their techniques, and what safeguards can be implemented against such threats.

Data mining is the first application of data privacy that we discuss. We explore two areas of mining: association rule mining and clustering. Each of these areas works with the goal of knowledge discovery. However, ensuring privacy is important for users/customers/patients to willingly share their data for analysis. In [Chapter 5](#), we explore a few prominent privacy preservation algorithms and conclude with a discussion on their impact on the utility of data.

The second application of privacy, test data, is increasingly becoming an area for privacy preservation. High-quality testing requires high-quality test data. Outsourcing of testing has brought data privacy concerns to the fore. Hence, in [Chapter 6](#), we discuss the need for privacy and current trends and list appropriate algorithms for each class of data. Measuring the utility of test data and also ascertaining the overall quality of test data are important to understand if a balance between privacy and utility has been achieved. Finally, the chapter also highlights some problems with the current anonymization options available.

In data mining and testing, there are times when a need arises to create external supplementary data. Classifiers require training data, which are not available initially. While testing too, special processes like error data handling, performance benchmarking, etc., require data not available in the original source data. Synthetic data generation solves both these issues. In [Chapter 7](#), we visit each class of personally identifiable information (PII) and explore the techniques available to generate synthetic data. The safety aspects of synthetic data are also covered in this chapter.

Run-time preservation of privacy is needed in cases where changes to the data itself

cannot be made. Another challenge is that different roles of users require different levels of protection. In such cases, tokenization is a good solution. Tokens preserve the formats of sensitive data, which make them look just like the original data. [Chapter 8](#) covers use cases, implementation and examples.

[Chapter 9](#), the final chapter, explores the compliance side of data privacy. Most privacy implementations are direct results of compliance mandates at the regional or organizational level. In this chapter, we explain the rules and definitions in some of the relevant privacy regulations. Most of this chapter is dedicated to HIPAA, which is the definitive privacy law in the United States for healthcare data.

[Appendix A](#) lists the principles of anonymization that are referred throughout this book. These principles are applicable across domains, thus providing a concrete guideline for data privacy implementations.

[Appendix B](#) (PPTDM Manifesto) summarizes the best practices to be applied while preserving privacy in a test data setting.

1.2 What Is Data Privacy and Why Is It Important?

Thousands of ambulance service staff and housing benefits claimants have had their personal information accidentally leaked in the latest UK data breach blunder (January 4, 2014; news in www.infosecurity-magazine.com/news/thousands-of-personal/-details.)

Natural healthcare chain Community Health Systems (CHS) says that about 4.5 million pieces of “non-medical patient identification data related to our physician practice” have been stolen.... August 18, 2014/News www.infosecurity-magazine.com/news/45-million-records-stolen-from/

NASDAQ-listed outsourcing firm EXL Service has lost a key client due to the breach of confidential client data by some of its employees.

- *Economic Times* (India) on November 6, 2013

There are numerous such incidents where customers’ confidential personal information has been attacked by or lost to a data snooper. When such untoward incidents occur, organizations face legal suits, financial loss, loss of image, and, importantly, the loss of their customers.

There are many stakeholders of data privacy in an organization; these are shown in [Figure 1.1](#). Let us define these stakeholders.

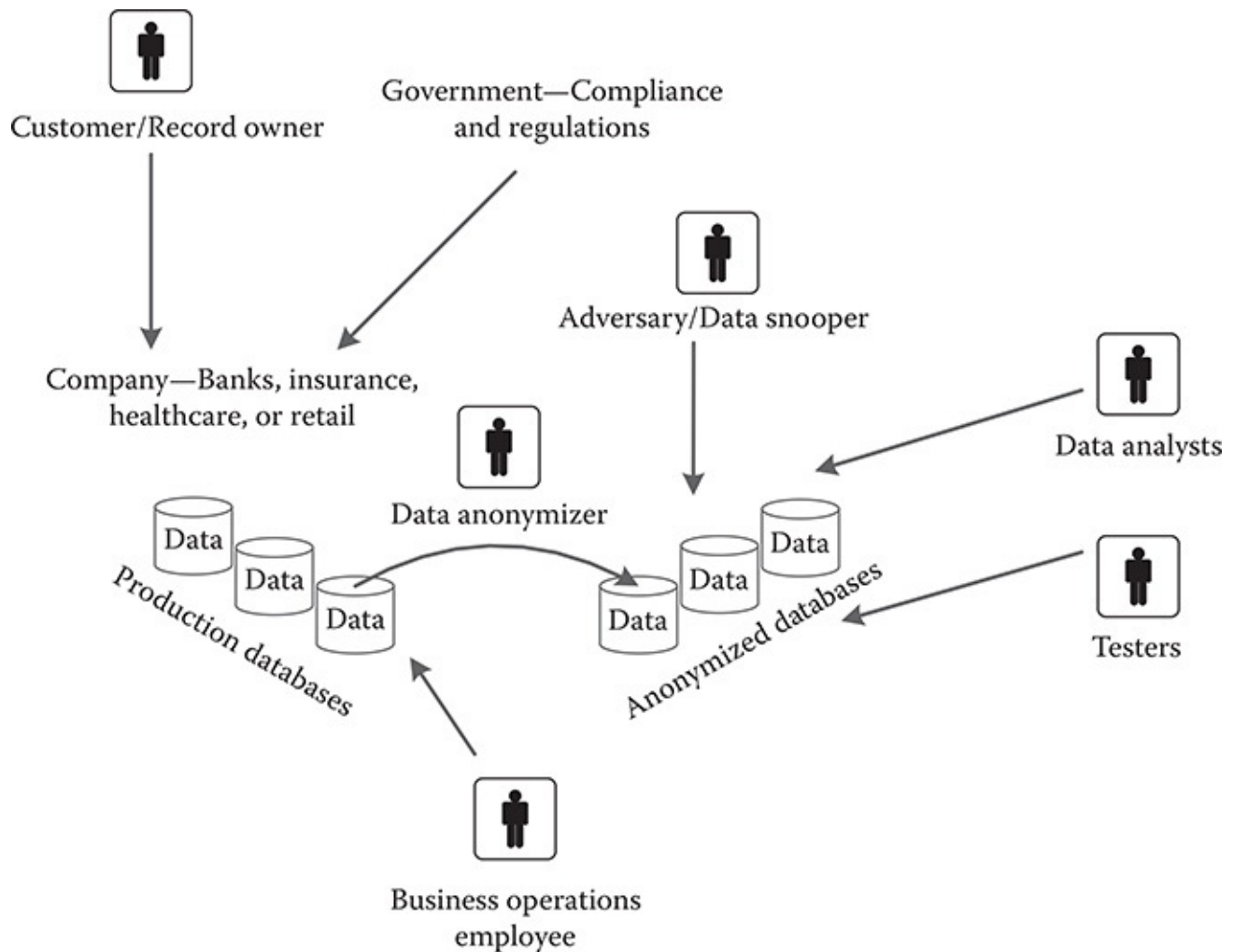


FIGURE 1.1
Data privacy—stakeholders in the organization.

Company: Any organization like a bank, an insurance company, or an e-commerce, retail, healthcare, or social networking company that holds large amounts of customer-specific data. They are the custodians of customer data, which are considered very sensitive, and have the responsibility of protecting the data at all costs. Any loss of these sensitive data will result in the company facing legal suits, financial penalties, and loss of reputation.

Customer/record owner: An organization's customer could be an individual or another organization who share their data with the company. For example, an individual shares his personal information, also known as PII, such as his name, address, gender, date of birth, phone numbers, e-mail address, and income with a bank. PII is considered sensitive as any disclosure or loss could lead to undesired identification of the customer or record owner. It has been shown that gender, age and zip code are sufficient to identify a large population of people in the United States.

Government: Government defines what data protection regulations that the company should comply with. Examples of such regulations are the HIPPA Act, the EU Data Protection Act, and the Swiss Data Protection Act. It is mandatory for companies to follow government

regulations on data protection.

Data anonymizer: A person who anonymizes and provides data for analysis or as test data.

Data analyst: This person uses the anonymized data to carry out data mining activities like prediction, knowledge discovery, and so on. Following government regulations, such as the Data Moratorium Act, only anonymized data can be used for data mining. Therefore, it is important that the provisioned data support data mining functionalities.

Tester: Outsourcing of software testing is common among many companies. High-quality testing requires high-quality test data, which is present in production systems and contains customer-sensitive information. In order to test the software system, the tester needs data to be extracted from production systems, anonymized, and provisioned for testing. Since test data contain customer-sensitive data, it is mandatory to adhere to regulatory compliance in that region/country.

Business operations employee: Data analysts and software testers use anonymized data that are at rest or static, whereas business operations employees access production data because they need to support customer's business requirements. Business operations are generally outsourced to BPO (business process outsourcing) companies. In this case too, there is a requirement to protect customer-sensitive data but as this operation is carried out during run-time, a different set of data protection techniques are required to protect data from business operations employees.

Adversary/data snooper: Data are precious and their theft is very common. An adversary can be internal or external to the organization. The anonymization design should be such that it can thwart an adversary's effort to identify a record owner in the database.

Companies spend millions of dollars to protect the privacy of customer data. Why is it so important? What constitutes personal information? Personal information consists of name, identifiers like social security number, geographic and demographic information, and general sensitive information, for example, financial status, health issues, shopping patterns, and location data. Loss of this information means loss of privacy—one's right to freedom from intrusion by others. As we will see, protecting one's privacy is nontrivial.

1.2.1 Protecting Sensitive Data

"I know where you were yesterday!" Google knows your location when you use Google Maps. Google maps can track you wherever you go when you use it on a smart phone. Mobile companies know your exact location when you use a mobile phone. You have no place to hide. You have lost your privacy. This is the flip side of using devices like smart phones, Global positioning systems (GPS), and radio frequency identification (RFID). Why should others know where you were yesterday? Similarly, why should others know your

health issues or financial status? All these are sensitive data and should be well protected as they could fall into the wrong hands and be exploited. Let us look at a sample bank customer and an account table. The customer table taken as such has nothing confidential as most of the information contained in it is also available in the public voters database and on social networking sites like Facebook. Sensitiveness comes in when the customer table is combined with an accounts table. A logical representation of [Tables 1.1](#) and [1.2](#) is shown in [Table 1.3](#).

Data D in the tables contains four disjointed data sets:

- 1. *Explicit identifiers (EI)*: Attributes that identify a customer (also called record owner) directly. These include attributes like social security number (SSN), insurance ID, and name.
- 2. *Quasi-identifiers (QI)*: Attributes that include geographic and demographic information, phone numbers, and e-mail IDs. Quasi-identifiers are also defined as those attributes that are publicly available, for example, a voters database.
- 3. *Sensitive data (SD)*: Attributes that contain confidential information about the record owner, such as health issues, financial status, and salary, which cannot be compromised at any cost.
- 4. *Nonsensitive data (NSD)*: Data that are not sensitive for the given context.

TABLE 1.1
Customer Table

Explicit Identifiers		Quasi-Identifiers				
ID	First Name	DOB	Gender	Address	Zip Code	Phone
1	Ravi	1970	Male	Fourth Street	66001	92345-67567
2	Hari	1975	Male	Queen Street	66011	98769-66610
3	John	1978	Male	Penn Street	66003	97867-00055
4	Amy	1980	Female	Ben Street	66066	98123-98765

TABLE 1.2
Account Table

ID	Sensitive Data				Nonsensitive Data
	Account Number	Account Type	Account Balance	Credit Limit	
1	12345	Savings	10,000	20,000	
2	23456	Checking	5,000	15,000	
3	45678	Savings	15,000	30,000	
4	76543	Savings	17,000	25,000	

TABLE 1.3
Logical Representation of Customer and Account Tables

Explicit Identifiers		Quasi-Identifiers				Sensitive Data			
ID	Name	DOB	Gender	Address	Zip Code	Account Number	Account Type	Account Balance	Credit Limit
1	Ravi	1970	Male	Fourth Street	66001	12345	Savings	10,000	20,000
2	Hari	1975	Male	Queen Street	66011	23456	Checking	5,000	15,000
3	John	1978	Male	Penn Street	66003	45678	Savings	15,000	30,000
4	Amy	1980	Female	Ben Street	66066	76543	Savings	17,000	25,000

The first two data sets, the EI and QI, uniquely identify a record owner and when combined with sensitive data become sensitive or confidential. The data set D is considered as a matrix of m rows and n columns. Matrix D is a vector space where each row and column is a vector

$$D=[D_{EI}][D_{QI}][D_{SD}] \quad (1.1)$$

Each of the data sets, EI, QI, and SD, are matrices with m rows and i, j, and k columns, respectively. We need to keep an eye on the index j (representing QI), which plays a major role in keeping the data confidential.

Apart from assuring their customers' privacy, organizations also have to comply with various regulations in that region/country, as mentioned earlier. Most countries have strong privacy laws to protect citizens' personal data. Organizations that fail to protect the privacy of their customers or do not comply with the regulations face stiff financial penalties, loss of reputation, loss of customers, and legal issues. This is the primary reason organizations pay so much attention to data privacy. They find themselves in a Catch-22 as they have huge amounts of customer data, and there is a compelling need to share these data with specialized data analysis companies. Most often, data protection techniques, such as

cryptography and anonymization, are used prior to sharing data. In this book, we focus only on anonymization.

Anonymization is a process of logically separating the identifying information (PII) from sensitive data. Referring to [Table 1.3](#), the anonymization approach ensures that EI and QI are logically separated from SD. As a result, an adversary will not be able to easily identify the record owner from his sensitive data. This is easier said than done. How to effectively anonymize the data? This is the question we explore throughout this book.

1.2.2 Privacy and Anonymity: Two Sides of the Same Coin

This brings up the interesting definition of privacy and anonymity. According to Skopek [1], under the condition of privacy, we have knowledge of a person’s identity, but not of an associated personal fact, whereas under the condition of anonymity, we have knowledge of a personal fact, but not of the associated person’s identity. In this sense, privacy and anonymity are flip sides of the same coin. [Tables 1.4](#) and [1.5](#) illustrate the fundamental differences between privacy and anonymity.

There is a subtle difference between privacy and anonymity. The word privacy is also used in a generic way to mean anonymity, and there are specific use cases for both of them. [Table 1.4](#) illustrates an anonymized table where PII is protected and sensitive data are left in their original form. Sensitive data should be in original form so that the data can be used to mine useful knowledge.

Anonymization is a two-step process: data masking and de-identification. Data masking is a technique applied to systematically substitute, suppress, or scramble data that call out an individual, such as names, IDs, account numbers, SSNs, etc. Masking techniques are simple techniques that perturb original data. De-identification is applied on QI fields. QI fields such as date of birth, gender, and zip code have the capacity to uniquely identify individuals. Combine that with SD, such as income, and a Warren Buffet or Bill Gates is easily identified in the data set. By de-identifying, the values of QI are modified carefully so that the relationship is still maintained by identities cannot be inferred.

TABLE 1.4
Example of Anonymity

Personal Identity						Sensitive Data			
SSN	Name	DOB	Gender	Address	Zip Code	Account Number	Account Type	Account Balance	Credit Limit
X	X	X	X	X	X				
X	X	X	X	X	X				
X	X	X	X	X	X				
X	X	X	X	X	X				

Note: X, identity is protected.

Copyright © 2016, CRC Press LLC. All rights reserved.

TABLE 1.5
Example of Privacy

Personal Identity						Sensitive Data			
SSN	Name	DOB	Gender	Address	Zip Code	Account Number	Account Type	Account Balance	Credit Limit
						X	X	X	X
						X	X	X	X
						X	X	X	X
						X	X	X	X

Note: X, sensitive data are protected.

In Equation 1.1, the original data set is D which is anonymized, resulting in data set $D' = T(D)$ or $T([D_{EI}][D_{QI}][D_{SD}])$, where T is the transformation function. As a first step in the anonymization process, EI is completely masked and no longer relevant in D' . As mentioned earlier, no transformation is applied on SD and it is left in its original form. This results in $D' = T([D_{QI}])$, which means that transformation is applied only on QI as EI is masked and not considered as part of D' and SD is left in its original form. D' can be shared as QI is transformed and SD is in its original form but it is very difficult to identify the record owner. Coming up with the transformation function is key to the success of anonymization design and this is nontrivial. We spend a lot of time on anonymization design, which is generally applied on static data or data at rest.

The other scenario is protecting SD, as shown in Table 1.5, which is applied on data in motion. The implementation of this is also very challenging.

It is dichotomous as organizations take utmost care in protecting the privacy of their customers' data, but the same customers provide a whole lot of personal information when they register on social network sites like Facebook (of course, many of the fields are not mandatory but most people do provide sufficient personal information), including address, phone numbers, date of birth (DOB), details of education and qualification, work experience, etc. Sweeney [2] reports that zip code, DOB, and gender are sufficient to uniquely identify 83% of population in the United States. With the amount of PII available on social networking sites, a data snooper with some background knowledge could use the publicly available information to re-identify customers in corporate databases.

In the era of social networks, de-identification becomes highly challenging.

1.3 Use Cases: Need for Sharing Data

Organizations tend to share customer data as there is much insight to be gained from customer-sensitive data. For example, a healthcare provider's database could contain how

patients have reacted to a particular drug or treatment. This information would be useful to a pharmaceutical company. However, these sensitive data cannot be shared or released due to legal, financial, compliance, and moral issues. But for the benefit of the organization and the customer, there is a need to share these data responsibly, which means the data are shared without revealing the PII of the customer. Figure 1.2 sets the context for this book, which illustrates the importance of enterprise-wide sensitive data protection. PII is found in all layers of architecture like business processes, applications, operational data stores (ODSs), data warehouse for historic data, time series databases, file servers for unstructured data, and reports. Whether data are shared with internal departments or external vendors, it is critical to protect the privacy of customer data. It is important to have an enterprise-wide privacy preservation design strategy to address the heterogeneity in data sources, data structures, and usage scenarios.

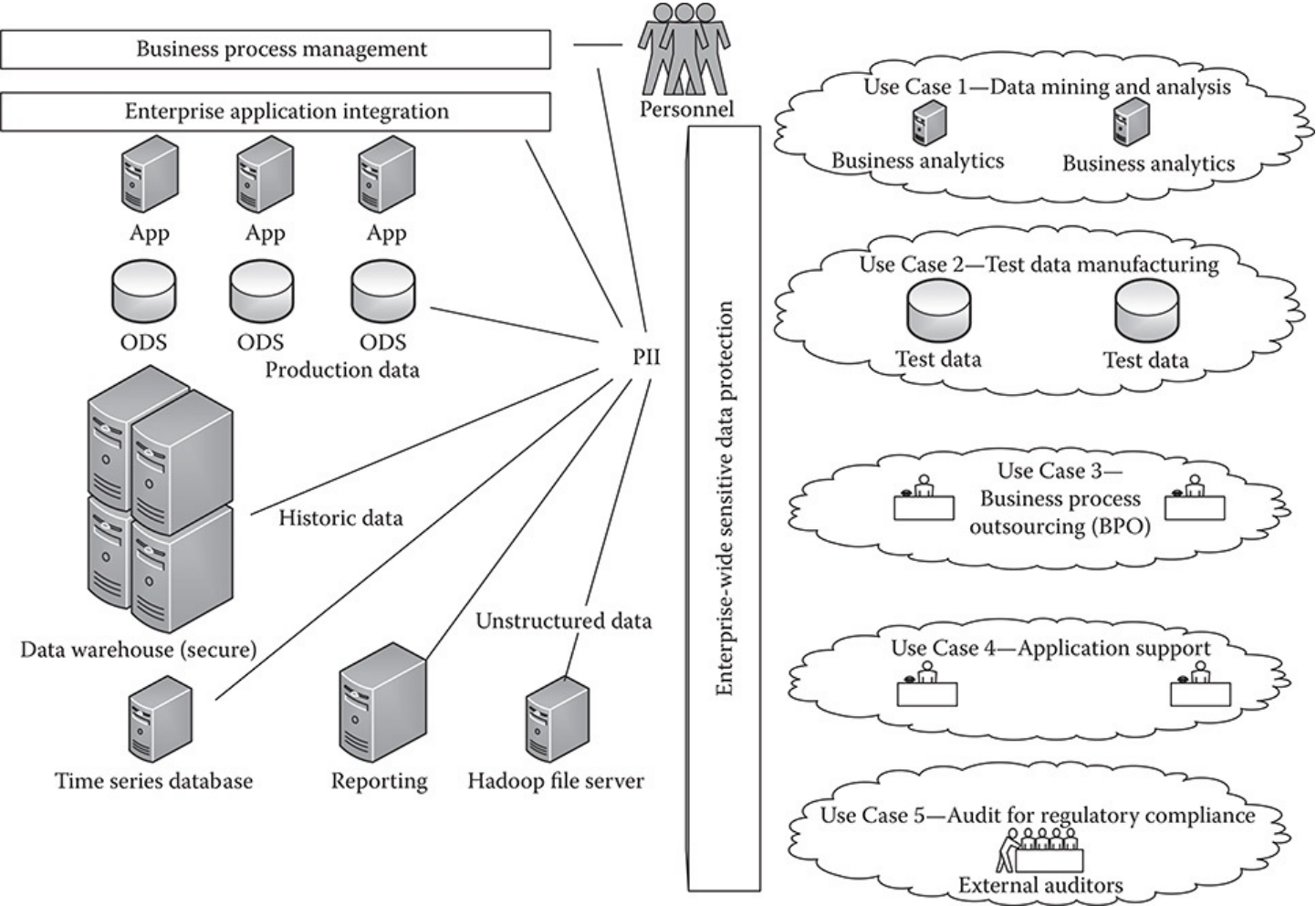


FIGURE 1.2
Sensitive data in the enterprise.

What are the relevant use cases for which data are shared by organizations? Let us now explore for what purposes the data are shared and how.

- Data mining and analysis

- Application testing
- Business operation
- Application support
- Auditing and reporting for regulatory compliance

These use cases can be classified under two categories:

1. Privacy protection of sensitive data at rest
2. Privacy protection of sensitive data in motion (at run-time)

The first two use cases fall under the first category and the rest under the second category. One important aspect to note here—without privacy preservation none of these use cases is feasible. [Figure 1.3](#) illustrates this concept. A brief coverage of some of the use cases is provided here, and they are dealt with in detail in dedicated chapters in the book.

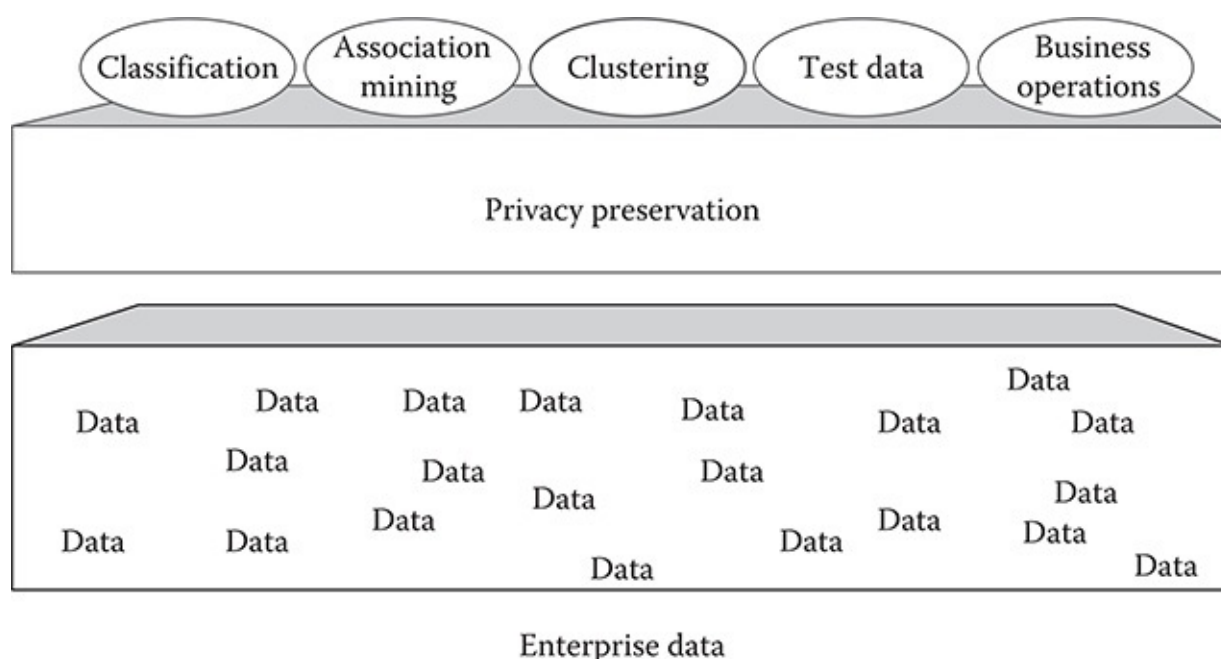


FIGURE 1.3
Use cases for privacy preservation.

1.3.1 Data Mining and Analysis

Banks would want to understand their customers' credit card usage patterns, a retail company would like to study customers' buying habits, and a healthcare company would like to understand the effectiveness of a drug or treatment provided to their patients. All these patterns are hidden in the massive amounts of data they hold. The intention of the company is to gather comprehensive knowledge from these hidden patterns. Data mining is the technique that is used to gather knowledge and predict outcomes from large quantities of data. The goal of data mining is to extract knowledge, discover patterns, predict, learn,

and so on. The key functional blocks in most data mining applications are classification, clustering, and association pattern mining.

Classification is defined as categorizing observations into various classes or groups. Classification is an approach for predicting qualitative discrete response variables—response will be either YES or NO. Many techniques are used for classification—decision trees, random forests, support vector machines, Bayesian classifiers, etc. An example could be that of customers defaulting on mortgage payments. In this case, the intention is to understand “customers in which income bracket will default on payments.” For this to work, the classifier needs to work on training data so that it can come up with a model to be used for prediction. Training data contain sensitive customer information. All this needs to be carried out in a way that preserves privacy. Training data are also not directly available. Synthetic data need to be generated to train this model, which will later need testing using some valid test data.

While classification comes under supervised learning where we are interested in predicting an outcome, clustering is an unsupervised learning technique for finding subgroups in the data set. The goal of clustering is exploratory learning rather than prediction. In order to protect the confidentiality of customer data, anonymization techniques are used to prevent identity and attribute disclosure, but the important aspect that needs to be considered is “what is the correct approach to anonymize in cluster analysis?” For example, are perturbative techniques more suitable than nonperturbative techniques for cluster analysis?

Association pattern mining is very similar to clustering and is defined in the context of sparse binary transaction databases where data entries are either 0 or 1. In this context, it should determine all the subsets of columns such that all the values in the columns take on the values of 1. For example, when a customer buys a product A, he will certainly also buy product B—this shows a strong association between A and B. Customers who buy bread may invariably buy butter. Association rule mining is extensively used in retail supermarkets (for positioning their products in store), healthcare, pharmaceuticals, and e-commerce companies. When such data are mined, customers’ transactions and their personal information could get compromised. Therefore, it is important to mine association rules or patterns in a way that preserves privacy.

1.3.2 Software Application Testing

A number of companies across the globe outsource their application testing. Outsourcing of testing is growing at about 20% every year. Application testing comprises functional requirements and nonfunctional requirements testing. Successful application testing requires high-quality test data. High-quality test data are present in production systems and this is sensitive customer data, which must be anonymized before sharing with testers. A high-level process of test data manufacturing is shown in [Figure 1.4](#). How to ensure the privacy of test data and at the same time make it useful for testing is examined in detail in [Chapter 6](#).

1.3.3 Business Operations

Many large companies across the globe outsource their business operations to business process outsourcing (BPO) companies in countries like India, China, and Brazil. For example, a financial services company outsources its business operations to a BPO company in India. Then that BPO company will assist customers of the financial services company in their business operations such as securities trading, managing their financial transactions, and so on. But access to a customer's trade account during these processes would expose a lot of sensitive information and this is not acceptable to the customer, and the regulation in the country will not permit such access. Therefore, these data have to be protected. But the question is how and what data are to be protected? A technique known as tokenization is used here wherein the sensitive data that should not be seen by the BPO employee are replaced with a token. This token has no relationship with the original data, and outside the context of the application the token has no meaning at all. All these are executed during run-time. Like privacy preserving data mining and test data management, protection of sensitive data is a subject in itself and is covered in depth in this book.

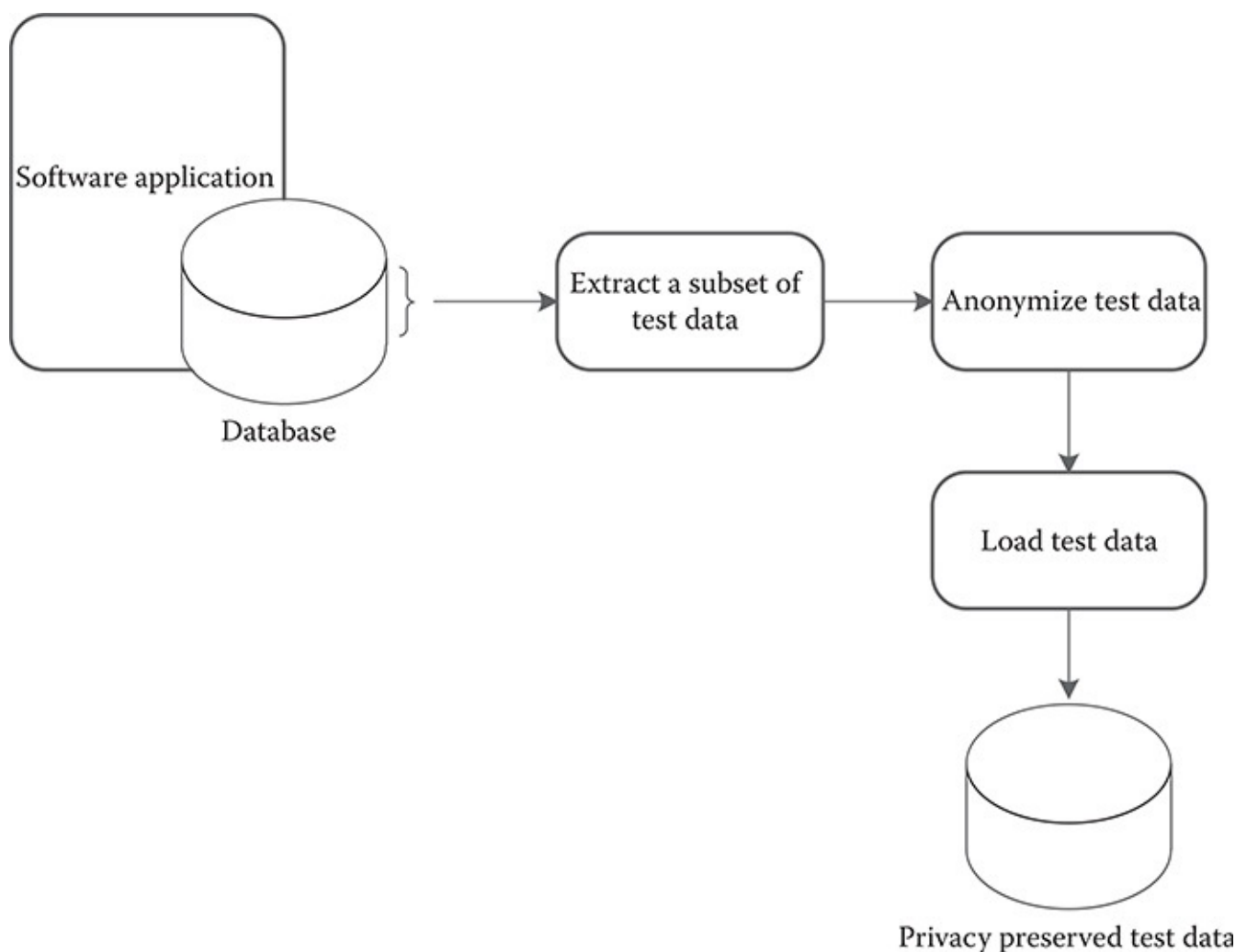


FIGURE 1.4

1.4 Methods of Protecting Data

One of the most daunting tasks in information security is protecting sensitive data in enterprise applications, which are often complex and distributed. What methods are available to protect sensitive data? Some of the methods available are cryptography, anonymization, and tokenization, which are briefly discussed in this section, and a detailed coverage is provided in the other chapters in the book. Of course, there are other one-way functions like hashing.

Cryptographic techniques are probably one of the **oldest** known techniques for data protection. When done right, they are probably one of the **safest** techniques to protect data **in motion and at rest**. **Encrypted data have high protection, but are not readable**, so how can we use such data? Another issue associated with cryptography is **key management**. Any compromise of key means complete loss of privacy. For the use cases discussed in this book, cryptographic techniques are not used widely. Of course, there are techniques like secure multiparty computation (MPC) and zero-knowledge proof (ZKP), which are discussed in detail in Duan and Canny [3].

Anonymization is a set of techniques **used to modify the original data** in such a manner that it does not resemble the original value but **maintains the semantics and syntax**. **Regulatory compliance and ethical issues drive the need for anonymization**. The intent is that anonymized data can be **shared freely** with other parties, who can perform their own analysis on the data. Anonymization is an **optimization problem**, in that when the original data are **modified** they **lose some of its utility**. But modification of the data is required to protect it. An **anonymization design is a balancing act between data privacy and utility**. **Privacy goals are set by the data owners, and utility goals are set by data users**. Now, is it really possible to optimally achieve this balance between privacy and utility? We will explore this throughout this book.

Tokenization is a **data protection technique** that has been extensively used in the **credit card industry** but is currently being **adopted in other domains** as well. Tokenization is a technique that **replaces the original sensitive data with nonsensitive placeholders referred to as tokens**. The fundamental difference between tokenization and the other techniques is that in tokenization, the **original data are completely replaced by a surrogate that has no connection to the original data**. **Tokens have the same format as the original data**. As tokens are not derived from the original data, they exhibit **very powerful data protection features**. Another interesting point of tokens is, although the token is usable within its native application environment, it is completely **useless elsewhere**. Therefore, tokenization is ideal to protect sensitive identifying information.

1.5 Importance of Balancing Data Privacy and Utility

In the introductory section, we looked at how an enterprise provisions data for purposes like application testing, knowledge discovery, and data analysis. We also emphasized the importance of privacy preservation of customer data before publishing them. Privacy preservation should also ensure utility of data. In other words, **the provisioned data should protect the individual's privacy and at the same time ensure that the anonymized data are useful for knowledge discovery**. By anonymizing the data, EI are completely masked out, QI is de-identified by applying a transformation function, and SD is left in its original form. There is a strong correlation between QI and SD fields. So, as part of privacy preservation, this correlation between QI fields and SD fields should not be lost. If the correlation is lost, then the resulting data set is not useful for any purpose.

As a transformation function is applied on QI, it is obvious that the correlation between QI fields and SD fields is affected or weakened, and this indicates how useful the transformed data are for the given purpose. Let us take an example from the healthcare domain to illustrate this important relationship between privacy and utility. HIPAA states that if any of the data elements are associated with health information, it makes that information personally identifiable. HIPAA defines 18 attributes as PII that include name, SSN, geographic information, demographic information telephone number, admission date, etc. [4]. Therefore, in any privacy preserving data analysis of health data, it should be ensured that any of these 18 attributes, if present, should be completely anonymized. If so much information is stripped off, then how can the remaining data be useful for the analysis? Let us take an example of a patient getting admitted to a hospital. According to the HIPAA privacy rules, the admission date is part of the patient's PII and therefore should be anonymized. The healthcare provider can share the patient's medical data to external partners for the analysis, but it will be impossible to analyze the efficacy of the treatment as the date of admission is anonymized as per HIPAA privacy laws. HIPAA's intention is to protect patient privacy, but it impacts medical research in the process. Therefore, it is extremely important to ensure the utility of the data while preserving privacy. In other words, there needs to be a balance between privacy and utility of anonymized data. [Figure 1.5](#) provides a map of privacy versus utility.

In the previous section, we looked at different mechanisms to protect data. **Cryptographic mechanism provides low utility (0) and high privacy (1) when data are encrypted** and it provides **high utility (1) and low privacy (0) when data are decrypted**. The privacy or utility in a cryptographic mechanism is either black (0) or white (1), whereas in anonymization methods, it is "shades of gray," meaning that it is possible to control the levels of privacy or utility. Anonymization can be viewed as constrained optimization—produce a data set with smallest distortion that also satisfies the given set of privacy requirements. But how do you balance the two contrasting features—privacy and utility?

Anonymized data are utilized in many areas of an organization like data mining,

analysis, or creating test data. An important point to remember here is each type of requirement or analysis warrants a different anonymization design. This means that there is no single privacy versus utility measure. To understand privacy versus utility trade-off, let us take the original data given in [Table 1.6](#).

- 1. Original data table with no privacy but high utility
- 2. High correlation between QI and SD (attributes fields)

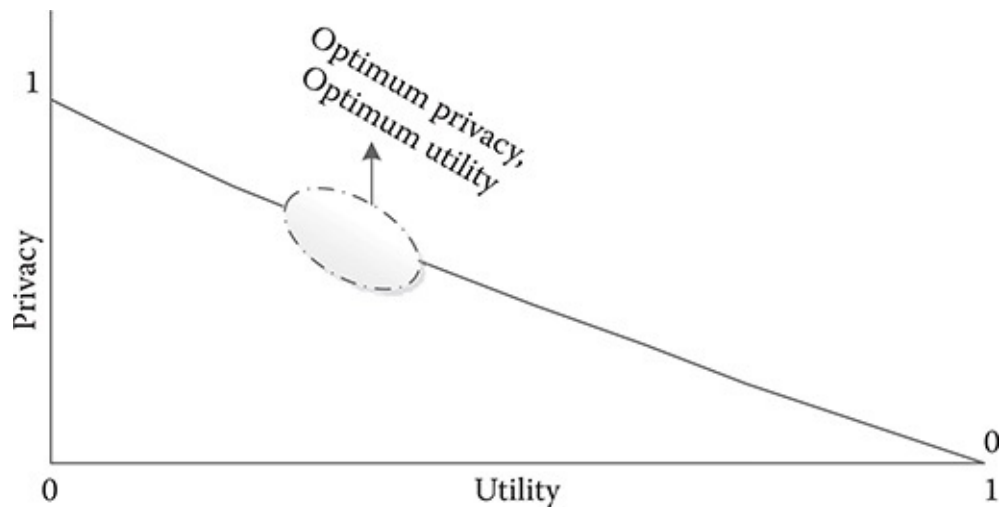


FIGURE 1.5
Privacy versus utility map.

TABLE 1.6
Original Table with Strong Correlation between QI and SD

Name	Zip Code	Gender	Income
Chen	56001	Male	25K
Jenny	56015	Female	8K
Alice	56001	Female	30K
Ram	56011	Male	5K

[Table 1.6](#) shows four individuals. Although many rows have not been shown here, let us assume that the ZIP CODE and INCOME are correlated, in that the ZIP CODE 56001 primarily consists of high-income individuals. [Table 1.7](#) is a modified version of [Table 1.6](#). Let us not worry about the techniques used to anonymize data, but focus just on the results. We can see that the names have been changed, the original ZIP CODES have been replaced with different values and INCOME values are unchanged.

Let us assess gains and losses for this anonymization design.

Privacy gain: Names are substituted (hence protected), financial standing is not attributed to another zip code, and geographical location is anonymized. Utility loss:

Gender information is preserved, names are substituted while preserving demographic clues, correlation is preserved but the zip code is different.

Another design can have just “XXXX” for all names, 56001 for all zip codes, and “Male” for all gender values. We can agree that this anonymization design scores well in terms of privacy, but utility is pathetic. Privacy gain: Names are completely suppressed, financial standing cannot be inferred, and geographical location is not compromised. Utility loss: Presence of females in the population, meaningless names lose demographic clues, flat value of zip code annuls the correlation.

This shows that anonymization design drives the extent of privacy and utility, which are always opposed to each other. The two designs also show that privacy or utility need not be 0 and 1 as in encryption; rather, both are shades of gray as stated earlier. A good design can achieve a balance between them and achieve both goals to a reasonable extent.

One way to quantify privacy is on the basis of how much information an adversary can obtain about the SD of an individual from different dimensions in the data set [5–8]. These references state that SD fields can be identified (or estimated/deduced) using QI fields. This is a very simple way to quantify privacy. In fact, this model does not capture many important dimensions, such as background knowledge of the adversary, adversary’s knowledge of some of the sensitive data, the complexity of the data structure, etc. We discuss this in sufficient detail in [Chapter 4](#).

The utility loss of a particular anonymization technique is measured against the utility provided by the original data set. A measure of utility is also the correlation between QI and SD preserved in the anonymized data. There are many anonymization techniques in use today, which can be broadly classified into perturbative and nonperturbative techniques. Each of these techniques provides its own privacy versus utility model. The core goals of these anonymization techniques are (1) to prevent an adversary from identifying SD fields and (2) to ensure minimal utility loss in the anonymized data set by ensuring high correlation between the QI and SD fields. This is easier said than done. These are extremely difficult goals to meet. To address this complex set of problem patterns, we have defined a rich set of anonymization design principles in [Appendix A](#).

TABLE 1.7
Anonymized Table with Generalized Values—Correlation between QI and SD Is Broken

Name	Zip Code	Gender	Income
Yang	56000	Male	25K
Emma	56010	Female	8K
Olivia	56000	Female	30K
Krishna	56010	Male	5K

1.5.1 Measuring Privacy of Anonymized Data

Given a data set D , a data anonymizer can create different anonymized data sets $D_1', D_2', \dots, D_n'$ based on different anonymization algorithm combinations for each attribute. Each of these anonymized data sets will have different privacy versus utility trade-offs. Privacy is a relative measure. This means that the privacy of D_1' is measured against another anonymized data set D_2' . There are multiple ways to measure the difference in privacy. These approaches are broadly classified into statistical and probabilistic methods. Some statistical approaches measure privacy in terms of the difference or variation in perturbed variables. The larger the variance, the better the privacy of the perturbed data. This technique is generally used for statistical databases.

Probabilistic methods measure privacy loss when an adversary has knowledge of the distribution of the data in the original data set and background information about some tuples in the data set. For example, consider the simple example in [Table 1.8](#).

Bob is the adversary and has some background information about Alice as she is his neighbor. Bob knows that Alice smokes heavily but does not really know what disease she is suffering from. However, he has knowledge about the distribution of the sensitive fields in a table containing medical records of a hospital that he has noticed Alice visiting. Bob then uses the knowledge of the distribution of SD fields and background information about Alice to identify her illness, which is cancer.

TABLE 1.8
Background Knowledge of the Adversary about the Distribution of SD Fields

Name	Zip Code	Gender	Disease
John Smith	46001	Male	Hypertension
Tom Henry	46005	Male	Gastritis
Alice Williams	46001	Female	Cancer
Little Wood	46011	Male	Asthma

1.5.2 Measuring Utility of Anonymized Data

Assume that in the original data D , QI , and SD are highly correlated. An example could be the correlation between demographic and geographic information, such as year of birth, country of birth, locality code, and income [10]. Data set D contains the truth about the relationship between demographic and geographic information and income. While anonymizing D , the truth should be preserved for the data to be useful. When D is anonymized to D' using a transformation function T , $D' = T(D)$, the QI fields are distorted to some extent in D' . Now, how true is D' ? Does the correlation between QI and SD fields in D' still exist? Each anonymization function will provide different levels of distortion. If Q is the distribution of QI fields in D and Q' is the distribution of QI fields in D' , then the statistical distance measure of Q and Q' provides an indication of the utility of D' [11]. This

reference provides a number of approaches to measure utility.

In [Chapter 6](#), we show that the quality of anonymized test data sets is one of the drivers for test coverage. The higher the quality of test data, the higher will be the test coverage. High-quality test data are present in production systems and contain PII. Privacy preservation results in poor test data quality or utility. Reduced utility reflects lower test coverage. We examine different anonymization approaches and resulting utility.

1.6 Introduction to Anonymization Design Principles

Anonymization design is not straightforward. As we saw in [Section 1.5](#), achieving a balance between privacy and utility has many dependencies. So, what are the drivers for anonymization design? Factors that drive anonymization design for a given requirement are illustrated in [Figure 1.6](#).

When there is a need for data privacy, organizations generally use either a commercial or a home-grown product for anonymizing data. It is critical to ensure that an organization's data anonymization program is not limited by the features of the product. Many organizations fail to maintain a balance between privacy and utility. It is generally difficult to determine how much anonymization is required, which results in either loss of information or the anonymized data set becoming unusable. Even with adoption of the best of breed data anonymization products, an organization's anonymization program may not be successful. In addition to this, the pressures of regulatory compliance force many organizations to be very defensive and adopt very high privacy standards that will render the data unusable for any research. Take, for example, HIPAA or Swiss Data Protection Act, which are highly restrictive with an intention to protect the privacy of an individual. If enough care is not taken, then the anonymized data could have very little utility. In this context, irrespective of which tool an organization uses, there is a need for a mechanism to monitor privacy versus utility for various privacy requirements. Unfortunately, quantifying privacy and utility is nontrivial. Therefore, it is critical to provide assurance of high quality of data anonymization during the initial phase of the anonymization life cycle. To support this, we felt it is necessary to define a set of design principles. These principles will provide the required guidelines for the data anonymizer to adopt the correct design for a given anonymization requirement.

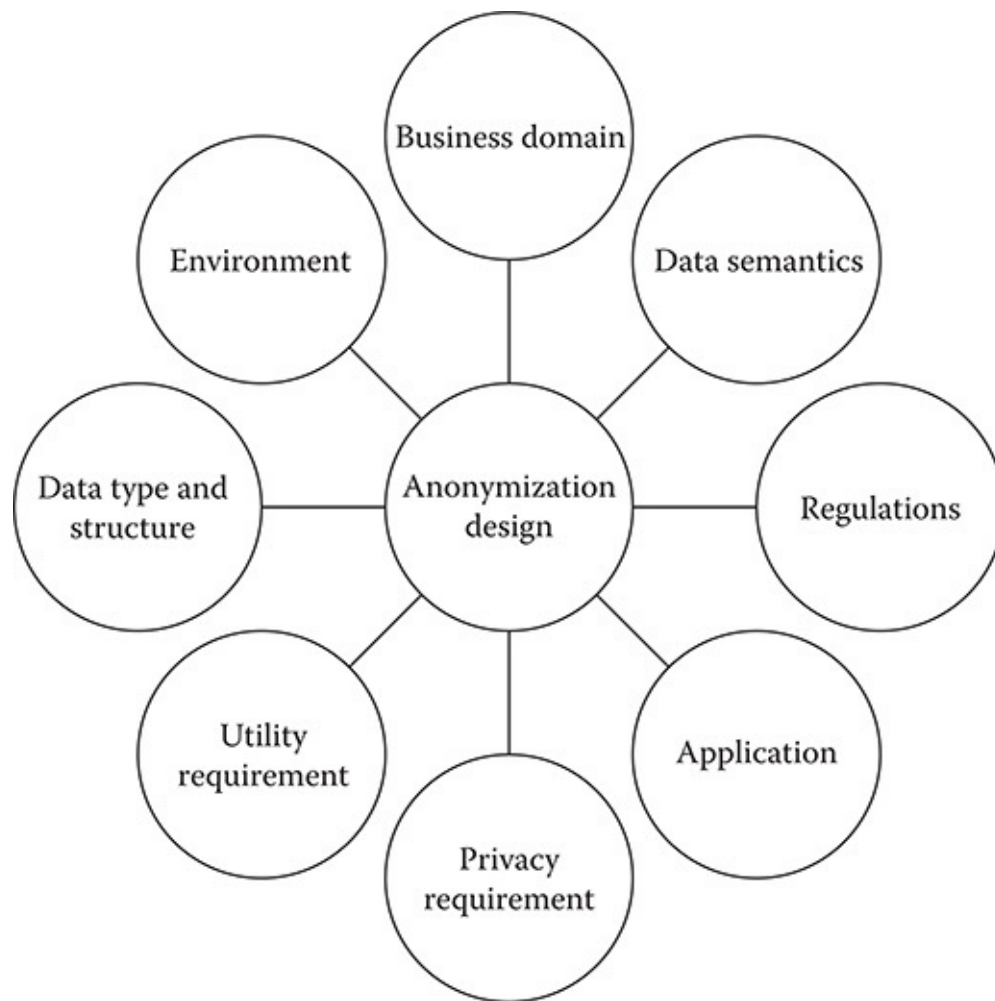


FIGURE 1.6
Drivers for anonymization design.

As software architects, we start the architecting process by following a set of architecture principles that will guide us to come up with the correct design for the system. We base our work here on a similar approach. In [12], the authors classify principles into two broad types—scientific and normative. Scientific principles are laws of nature and form the fundamental truths that one can build upon. Normative principles act as a guide and need to be enforced. Similarly, a data anonymizer needs guidance, and the anonymization design principles should be enforced to ensure proper anonymization design. These principles are fundamental in nature and are applicable to all aspects of anonymization. They connect the high-level privacy and utility requirements to low-level implementation.

In this book, all principles are explained in the following form:

- Principle Name
- Rationale
- Implications

These anonymization principles can be found in [Appendix A](#).

1.7 Nature of Data in the Enterprise

1.7.1 Multidimensional Data

Multidimensional data also referred to as relational data are the most common format of data available today in many enterprises. In a relational table, each row is a vector that represents an entity. The columns represent the attributes of the entity. As relational data are the most common data format, a lot of attention has been paid to privacy preservation of relational data [2,13,14]. As described earlier, a row of data in a relational table is classified into explicit identifiers, quasi-identifiers, sensitive data, and nonsensitive data. Both perturbative and nonperturbative techniques could be used to protect the data. As a rule, EI are completely masked out, QI are anonymized, and SD are left in their original form. (These terms are explained in detail in [Chapter 2](#).) Depending on the sensitivity of data, appropriate data protection techniques can be applied. The fundamental differences between anonymizing multidimensional data and other data structures are as follows:

- In a multidimensional data table, each record or row is independent of others; therefore, anonymizing a few of the records will not affect other records.
- Anonymizing a tuple in a record will not affect other tuples in the record.

Other complex data structures, such as graph, longitudinal, or time series data, cannot be viewed in this way. Privacy preservation for multidimensional data can be classified into (1) random perturbation methods and (2) group anonymization techniques, such as k -anonymity or l -diversity. These techniques are used to prevent identity disclosure and attribute disclosure.

1.7.1.1 Challenges in Privacy Preservation of Multidimensional Data

The challenges in this kind of data preservation are as follows:

1. Difficulty in identifying the boundary between QI and SD in the presence of background knowledge of the adversary
2. High dimensionality of data poses a big challenge to privacy preservation
3. Clusters in sensitive data set
4. Difficulty in achieving realistic balance between privacy and utility

1.7.2 Transaction Data

Transaction data are a classic example of sparse high-dimensional data. A transaction database holds transactions of a customer at a supermarket or it can be used to hold the diagnosis codes of a patient in a hospital. Privacy of transaction data is very critical as an adversary who has access to this database can obtain the shopping preferences of customers

and exploit that information. But the problem with transaction database is that it is of very high dimensionality and sparsely filled. A supermarket will have thousands of products contributing to the high dimensionality of the transaction database. Moreover, the transactional data contained in the database are binary—either 0 or 1. An event of a transaction is represented by 1; otherwise, it would be a 0 (Table 1.9).

In this table, P_1 – P_n represents the products in the supermarket. The customer Hari has made a transaction on P_3 and P_6 , which means his shopping cart contains product P_3 and P_6 , say bread and cheese. There is nothing sensitive about a customer buying bread and cheese. But if the product happens to be a blood glucose or blood pressure monitor, then that transaction is sensitive from the customer’s perspective as he would not want others to know that he is diabetic. It is the sensitivity of the transaction that needs to be protected. Privacy preservation techniques used in the case of relational data table will not be applicable here.

TABLE 1.9
Sample Sparse High-Dimensional Transaction Database in a Supermarket

Name	P_1	P_2	P_3	P_4	P_5	P_6	P_n
Hari			1			1	
Nancy	1			1			
Jim		1					1

1.7.2.1 Challenges in Privacy Preservation of Transaction Data

Some of the challenges in privacy preservation of transaction data are as follows:

- 1. High dimensionality.
- 2. Sparsity.
- 3. Conventional privacy preservation techniques used for relational tables that have fixed schema are not applicable on transaction data.

1.7.3 Longitudinal Data

Longitudinal studies are carried out extensively in the healthcare domain. An example would be the study of the effects of a treatment or medicine on an individual over a period of time. The measurement of the effects is repeatedly taken over that period of time on the same individual. The goal of longitudinal study is to characterize the response of the individual to the treatment. Longitudinal studies also help in understanding the factors that influence the changes in response. Consider the following table that illustrates the effect of treatment for hypertension in a patient (Table 1.10).

The table contains a longitudinal set D , which has three disjoint sets of data—EI, QI,

and SD. A few important characteristics of the data set D that must be considered while designing an anonymization approach are as follows:

- Data are clustered—composed of repeated measurements obtained from a single individual at different points in time.
- The data within the cluster are correlated.
- The data within the cluster have a temporal order, which means the first measurement will be followed by the second and so on [15].

TABLE 1.10
Sample Longitudinal Data Set in the Healthcare Domain

ID	Name	DOB	ZIP	Service Date	Diseases	Systolic (mmHg)	Diastolic (mmHg)
1	Bob	1976	56711	30/05/2012	Hypertension	180	95
2	Bob	1976	56711	31/05/2012	Hypertension	160	90
3	Bob	1976	56711	01/06/2012	Hypertension	140	85
4	Bob	1976	56711	02/06/2012	Hypertension	130	90
5	Bob	1976	56711	03/06/2012	Hypertension	125	85
6	Bob	1976	56711	04/06/2012	Hypertension	120	80
7	Alice	1969	56812	31/03/2012	Hypertension	160	90

These are to be noted because the anonymization design should ensure that these characteristics of D are preserved in the anonymized data set D', otherwise, the truth in the data will be lost.

1.7.3.1 Challenges in Anonymizing Longitudinal Data

Anonymization design for longitudinal data should consider two aspects:

1. The characteristics of longitudinal data in the anonymized data set D' should be maintained.
2. Anonymization designs aim to prevent identity and attribute disclosure.

Consider the longitudinal data set D, which has three disjoint sets of data (EI, QI, and SD). EI are completely masked to prevent identification. QI are anonymized using generalization and suppression to prevent identity disclosure. In the case of longitudinal data, anonymizing identity attributes alone is not sufficient to prevent an adversary from re-identifying the patient. An adversary can still link some of the sensitive attributes to the publicly available data, that is, medical records. Now comes the need to prevent attributes disclosure. For longitudinal data, an anonymization design that prevents identity as well as attributes disclosure is required [16]. There are a number of techniques to prevent identity disclosure, such as perturbative and nonperturbative techniques. Effective anonymization

techniques are required to prevent attributes disclosure, but these techniques should also ensure that they preserve the characteristics of longitudinal data.

1.7.4 Graph Data

Graph data are interesting and found in many domains like social networks, Electronics, Transportation, Software, and Telecom. A graph $G = (V,E)$ consists of a set of vertices together with a set of vertex pairs or edges. Graphs are interesting as they model almost any relationship. This is especially relevant in modeling networks like financial networks and also social networks like Facebook, LinkedIn, and Twitter. It is in these types of applications, we see the need for privacy preservation of graph data. Social networks have many users and contain a lot of personal information, such as network of friends and personal preferences. Social network data analytics is a rich source of information for many companies that want to understand how their products are received by the customers. For example, a bank would like to get feedback from their customers about the various financial products and services they offer. The bank can have its own page on, say, Facebook where its customers provide their views and feedback. Publishing these data for mining and analysis will compromise the privacy of the customers. Therefore, it is required to anonymize the data before provisioning it for analytics. However, graph data are complex in nature. The more complex the data structure, the easier it is to identify entities [17].

Due to the complexity of graph data, the anonymization design applied is different compared to that applied to relational data tables. In the case of relational data tables, each row is treated as an entity and its QI are anonymized to prevent identity disclosure. The attack model in relational data is also straightforward. An adversary will use an external data source to identify an individual via the QI. Graph data are more complex, and because of their complexity they provide more avenues for re-identification. Consider the network shown in Figures 1.7 and 1.8.

Figure 1.7 depicts a network with original data of users. The same has been anonymized in Figure 1.8. Will this anonymization be enough to thwart an adversary’s attempt to re-identify the users? The simple answer is no. The many challenges in anonymizing graph data are discussed next.

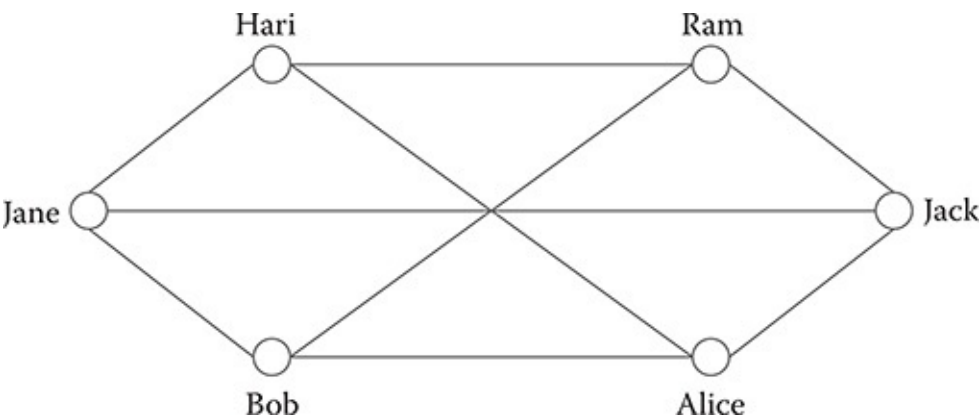


FIGURE 1.7

Graph network with original data.

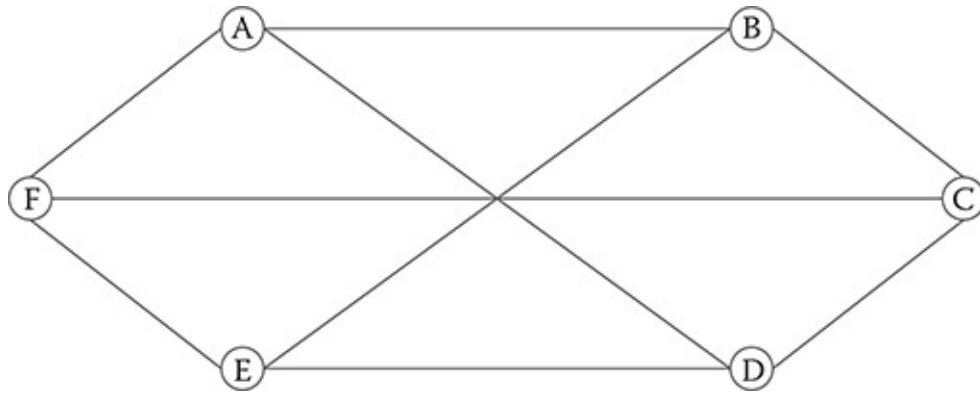


FIGURE 1.8
Modified graph network.

1.7.4.1 Challenges in Anonymizing Graph Data

Privacy of graph data can be classified into three categories [18]:

1. Identity disclosure
2. Link disclosure
3. Content/attribute disclosure

Apart from these, graph metrics such as betweenness, closeness, reachability, path length, and centrality can also be used to breach the privacy of target individuals in a graph network.

Identity disclosure: Identity disclosure occurs when it is possible to identify the users in the network.

Content disclosure: Just as in relational table, sensitive content is associated with each node (entity). This sensitive content is classified into explicit identifiers like name, SSN, and QI, such as demographics, gender, date of birth, and other sensitive data such as preferences and relationships.

Link disclosure: Links between users are highly sensitive and can be used to identify relationships between users.

It is very challenging to anonymize graph data as it is difficult to devise an anonymizing design. For the graph to maintain privacy and utility after anonymization, the techniques need to alter the graph, but just enough to prevent identity, content, and link disclosure. At the same time, changing the nodes or labels could affect other nodes in the network and could potentially alter the structure of the network itself. Meanwhile, there are multiple avenues to identify a user in a graph network since it is difficult to model the

adversary’s background knowledge. How to provision graph data in a privacy preserving way for mining and analysis? What anonymization techniques are available for graph data?

1.7.5 Time Series Data

Time series data result from taking measurements at regular intervals of time from a process. An example of this could be temperature measurement from a sensor or daily values of a stock, the net asset value of a fund taken on a daily basis, or blood pressure measurements of a patient taken on a weekly basis. We looked at longitudinal data where we considered the response of a patient to blood pressure medication. The measurements have a temporal order. So, what is the difference between longitudinal data and time series data? Longitudinal data are extensively used in the healthcare domain, especially in clinical trials. Longitudinal data represent repeated measurements taken on a person. These measurements are responses to a treatment or drug, and there is a strong correlation among these measurements. A univariate time series is a set of long measurements of a single variable taken at regular intervals, say, blood pressure measurements of a patient taken over a period of time. These measurements need not necessarily be a response to a drug or treatment. Longitudinal data have very small dimensions compared to time series data that have high dimensional and keep growing. Sample time series data showing weekly sales of their products are given in Table 1.11.

TABLE 1.11
Sample Time Series Data Table Showing Weekly Sales of Companies

ID	Company Name	Address	Week 1	Week 2	Week 3	Week 4	Week 5
1	ABC	Park Street, 56001	10,000	12,000	17,000	8,000	11,000
2	ACME	Kings Street, 56003	15,000	17,000	18,000	20,000	21,000
3	XYZ	Main Street, 56022	20,000	23,000	25,000	26,000	30,000
4	PQR	Queen Street, 56021	14,000	18,000	19,000	19,500	21,000

It can be observed from the table that each record has three disjoint sets of data—EI, QI, and SD. This is very similar to the structure of multidimensional data. But that is where the similarity ends. In multidimensional data, each record is independent of the others and can be anonymized without affecting other records. The tuples in each record can be anonymized without affecting other tuples in the record. But this approach cannot be used with time series data because of its large size, high dimensionality, and pattern. This makes privacy preservation rather challenging.

1.7.5.1 Challenges in Privacy Preservation of Time Series Data

Some of the challenges in privacy preservation of the time series data are as follows:

Copyright © 2016, CRC Press LLC. All rights reserved.

- High dimensionality
- Retaining the statistical properties of the original time series data like mean, variance, and so on
- Supporting various types of queries like range query or pattern matching query
- Preventing identity disclosure and linkage attacks

References

1. J.M. Skopek, Anonymity: The production of goods and institutional design, *Fordham Law Review*, 82(4), 1751–1809, 2014, <http://ir.lawnet.fordham.edu/flr/vol82/iss4/4/>.
2. L. Sweeney, k-Anonymity: A model for protecting privacy, *International Journal of Uncertainty, Fuzziness and Knowledge Based Systems*, 10 (5), 557–570, 2002.
3. Y. Duan and J. Canny, Practical distributed privacy-preserving data analysis at large scale, in *Large Scale Data Analytics*, A. Gkoulalas-Divanis, A. Labbi (eds.), 2014 Springer.
4. Summary of the HIPAA Privacy Rule, <http://www.hhs.gov/ocr/privacy/hipaa/understanding/summary/index.html>. Accessed October, 2015
5. A. Machanavajjhala et al., l-Diversity: Privacy beyond k-Anonymity, in *Proceedings of the 22nd International Conference Data Engineering (ICDE 2006)*, Atlanta, GA, 2006, p. 24.
6. T. Li and N. Li, On the trade-off between privacy and utility in data publishing, in *Proceedings of the 15th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, ACM, Paris, France, June 28–July 1, 2009, pp. 517–525.
7. N. Li, T. Li, and S. Venkatasubramanian, t-closeness: Privacy beyond k-anonymity and l-diversity, in *Proceedings of the IEEE International Conference Data Engineering (ICDE 2007)*, 2007, Istanbul, Turkey, pp. 106–115.
8. R.C.-W. Wong, J. Li, A.W.-C. Fu, and K. Wang, (α , k)-anonymity: An enhanced k-anonymity model for privacy preserving data publishing, in *Proceedings of the 12th International Conference on Knowledge Discovery and Data Mining*, 2006, Philadelphia, PA, pp. 754–759.
9. X. Xiao and Y. Tao, Anatomy: Simple and effective privacy preservation, in *Proceedings of the 32nd International Conference on Very Large Data Bases (VLDB 2006)*, Seoul, South Korea, 2006, pp. 139–150.
10. N. Shlomo, Accessing microdata via the internet, Joint UN/ECE and Eurostat work session on statistical data confidentiality, Luxembourg, April 7–9, 2003.
11. D. Kifer and J. Gehrke, Injecting utility into anonymized datasets, in *Proceedings of the ACM SIGMOD International Conference on Management of Data (SIGMOD 2006)*, Chicago, IL, June 27–29, 2006.
12. D. Greefhorst and E. Proper, *Architecture Principles: The Cornerstone of Enterprise Architecture*, Springer, Berlin, Heidelberg, 2011.
13. P. Samarati, Protecting respondents identities in micro data release, in *IEEE Transactions on Knowledge Data Engineering*, 2001, pp. 1010–1027.
14. C.C. Aggarwal, On k-anonymity and curse of dimensionality, in *Proceedings of the Very Large Data Base*, Trondheim, Norway, 2005, pp. 901–909.
15. G.M. Fitzmaurice, N.M. Laird, and J.H. Ware, *Applied Longitudinal Analysis*, 2nd edn., Wiley, August 30, 2011.
16. M. Sehatkar and S. Matwin, HALT: Hybrid anonymization of longitudinal transaction, in *11th Annual Conference on Privacy, Security and Trust (PST)*, IEEE, 2013, Tarragona, Spain, pp. 127–137.
17. M.L. Maag, L. Denoyer, and P. Gallinari, Graph anonymization using machine learning, in *The 28th IEEE International Conference on Advanced Information Networking Application*, 2014, Victoria, BC, Canada, pp. 1111–1118.
18. E. Zheleva and L. Getoor, Preserving the privacy of sensitive relationships in graph data, in *Proceedings of the*

First ACM SIGKDD International Workshop in Privacy, Security and Trust, 2007, San Jose, CA.

19. B.E. Burke, Information protection and control survey: Data loss prevention and encryption trends. IDC Special Study, Doc. # 211109, 2008.

Static Data Anonymization Part I: Multidimensional Data

2.1 Introduction

In [Chapter 1](#), we looked at various data structures such as multidimensional data, graph data, longitudinal data, transactional data, and time series data. We also understood what attributes in these data structures are to be anonymized. In this chapter, we look at how to effectively anonymize data, anonymization algorithms, quality aspects of algorithms, and privacy versus utility features. This book deals with two main applications of static data anonymization—privacy preserving data mining (PPDM) and privacy preserving test data management (PPTDM)—while the focus is on the study of various anonymization techniques in these application areas.

Static data anonymization deals with protecting identities and preventing breaches on data that are at rest. In this chapter, we focus on multidimensional or relational data, while the next chapter introduces anonymization techniques in complex data structures. Relational data also known as multidimensional data are the easiest format in which data are represented today. Multidimensional data are both easy to work upon and understand, the latter making it an easy target for privacy attacks. This chapter will take us through the classification of data, protection mechanisms of each class, and a look at some popular group anonymization techniques that are in use today.

2.2 Classification of Privacy Preserving Methods

A multidimensional data set D consists of four disjoint sets of data: explicit identifiers (EI), quasi-identifiers (QI), sensitive data (SD), and nonsensitive data (NSD). EI consist of identification numbers such as SSN and vehicle identification numbers (VIN), and names (first, last, and middle), or, in other words, any identifier that can directly identify a record

owner. QI consist of identifiers such as age, data of birth, address, phone numbers, and so on. These identifiers are categorical attributes, mainly categorical nominal. No arithmetic operations are possible on nominal values, but their finite value range needs to be used while designing anonymization methods.

Sensitive data sets consist of numerical data or strings. Usually, SD are left in their original form to enable the utility of data. But there are exceptional scenarios where it is necessary to protect SD also to some extent.

Data protection methods can be classified into two groups, as shown in [Figure 2.1](#).

To effectively anonymize data, more than one technique needs to be used. Consider a multidimensional data set D shown in [Table 2.1](#).

Data Table D is classified into three disjoint sets of data. This is the first critical step in anonymization design.

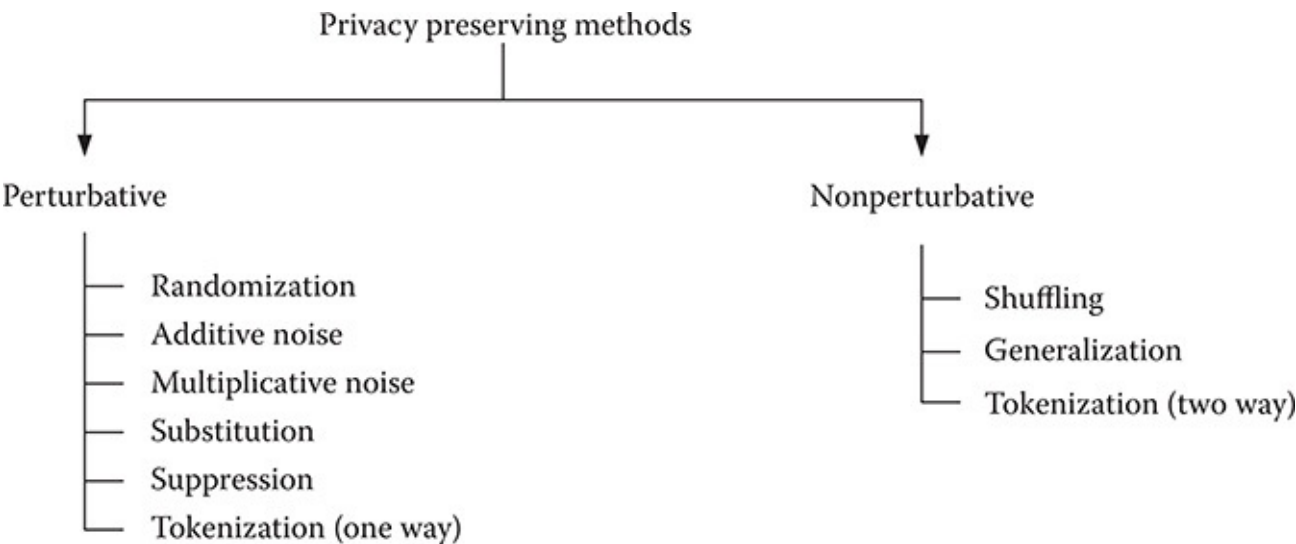


FIGURE 2.1
Classification of privacy preserving methods.

TABLE 2.1
Sample Salary Data Table

EI		QI				SD			
ID	Name	Gender	Age	Address	Zip	Basic	HRA	Med	All
12345	John	M	25	1, 4th St.	560001	10,000	5,000	1000	6,000
56789	Harry	M	36	358, A dr.	560068	20,000	10,000	1000	12,000
52131	Hari	M	21	3, Stone Ct	560055	12,000	6,000	1000	7,200
85438	Mary	F	28	51, Elm st.	560003	16,000	8,000	1000	9,600
91281	Srini	M	40	9, Ode Rd	560001	14,000	7,000	1000	8,400
11253	Chan	M	35	3, 9th Ave	560051	8,000	4,000	1000	4,800



2.3 Classification of Data in a Multidimensional Data Set

Classify the data set D as per Principle (1) into EI, QI, SD, and NSD with clear boundaries between them.

2.3.1 Protecting Explicit Identifiers

A multidimensional database consists of attributes of different data types, such as numeric, strings, and so on. Data anonymization methods should focus on the semantics of the data and not the syntax.

Principle (8): Understand the semantics of the data in the context of the application so as to apply the correct/appropriate anonymization technique on the data.

Example: EI identify a record owner explicitly and as such should be completely masked. Consider Table 2.1. There are two identifiers that are EI: ID and Name (Table 2.2).

EI generally include identifying fields such as SSN, VIN, driver’s license number, tax number, and so on. In a multidimensional database, which is also represented as a relational database, identifying fields, such as SSN, are very commonly used as a primary key in a relational data model design. Whether this is a good practice or not is debatable, but this is often the case. Moreover, these identifying fields are commonly found in downstream and upstream applications in the enterprise. Therefore, while masking these fields, it is critical to take care of two aspects.

TABLE 2.2
Tokenizing ID and Substituting Name

ID	Name	ID	Name
(a) Original EI		(b) Masked EI	
12345	John	40011	Jack
56789	Harry	81100	Sammy
52131	Hari	62410	Mark
85438	Mary	79820	Jane
91281	Srini	14532	Singh
11253	Chan	22244	Khan

Tokenization
(one way)
algorithm

Name
Database

1. Referential integrity
2. Consistently masking across databases

Principle (4): Ensure consistency in masking data across applications in a domain.

To preserve the format of identifying attributes and also bring in consistency across applications in a domain, we suggest a tokenization (one-way)-based algorithm.

The tokenization method generates a unique token for a given input. For example,

Input data: 12345 → TOKENIZE → output token: 40011

So, whenever the input data are 12345, the tokenization algorithm will always generate the same unique token, for example, 40011. The main advantage of tokenization is that it is highly secure, that is, tokens generated have no relationships with the original input data. The token 40011 has no meaning outside the context of the application or domain. The other advantage is that the tokenization algorithm preserves the format of the input data. Moreover, tokenization is not restricted to numeric data types and can be used for other data types, such as strings.

Tokenization is a special form of randomization. In randomization, the transformed data are related to the original data via the randomization function, whereas a tokenized value has no relationship to the original data. The tokenization function generates the tokenized value that is independent of the original data and thus provides a much stronger data protection mechanism. Randomization, however, is weaker when compared to tokenization as prior knowledge of the randomization method will help in identifying the original data.

Tokenization has two variants

1. One-way tokenization
2. Two-way tokenization

One-way tokenization generates unique tokens from which the original data cannot be identified. In two-way tokenization, every input data are mapped to a unique token. The tokens replace the original input data. During a transaction, the original input data are recovered as the mapping between the input data and token is available. Two-way tokenization is extensively used in the credit card industry and is now adopted across other industry verticals. As an example, consider a credit card number that has 16 digits.

16-digit credit card	4142 3215 4213 5015
16-digit tokenized data	4154 4155 5261 5015
	↓
	UNIQUE TOKEN

It is impossible to re-identify the original credit card number from the tokenized data

(Figure 2.2)

Two-way tokenization is generally used during run-time or dynamically to address privacy issues. We cover two-way tokenization in sufficient detail in Chapter 8.

Protecting name fields is very important as any disclosure will lead to complete loss of privacy. The best way to protect names of the record owner is to remove them from the published data and substitute them with fictitious names from lookup databases. Substitution is a mechanism by which the original data are replaced or substituted with alternative data values. Figure 2.3 illustrates how substitution works with name fields.

Figure 2.3 illustrates an example of the substitution method, in which the names in the original data table for the North American region are substituted with similar names obtained from an external data source. On the Internet, we can get name databases pertaining to different countries and regions. For example, one can obtain a database containing Spanish names, English names, or Indian Names. As their names are fictitious, they could be safely substituted in place of original names, thus protecting the privacy of the record owner.

EI normally consist of identifying attributes, such as SSN, VIN, passport number, driver’s license number, tax number, and names (first, middle, and last). What we have shown here is how to effectively mask them to protect the identity of the record owner. But certain attributes such as record owner’s phone number, mobile number, and e-mail IDs are difficult to classify into EI or QI. Residential landline number of the record owner directly identifies him, but his office board number does not directly identify him. If the adversary has knowledge of the record owner’s phone number and e-mail ID, then it is a violation of the record owner’s privacy. So, under which group, EI or QI, do you place the record owner’s phone number (residence, landline, office number, mobile number)?

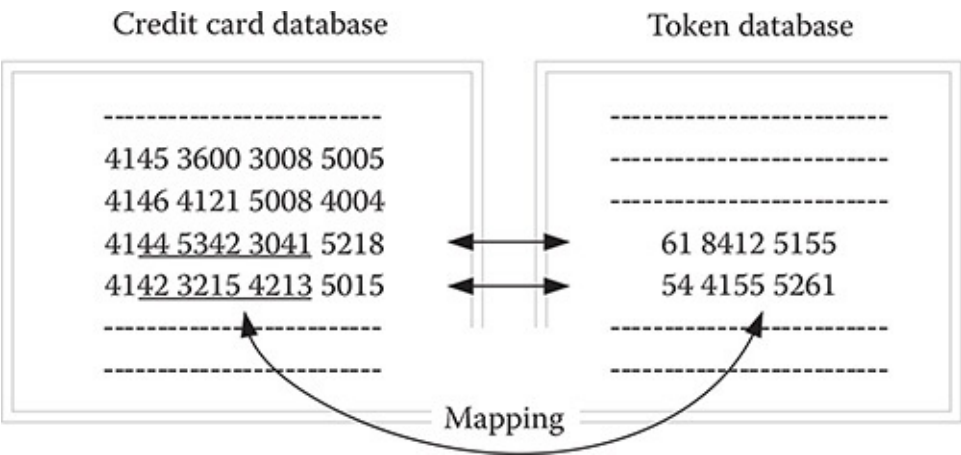


FIGURE 2.2
Example of two-way tokenization.

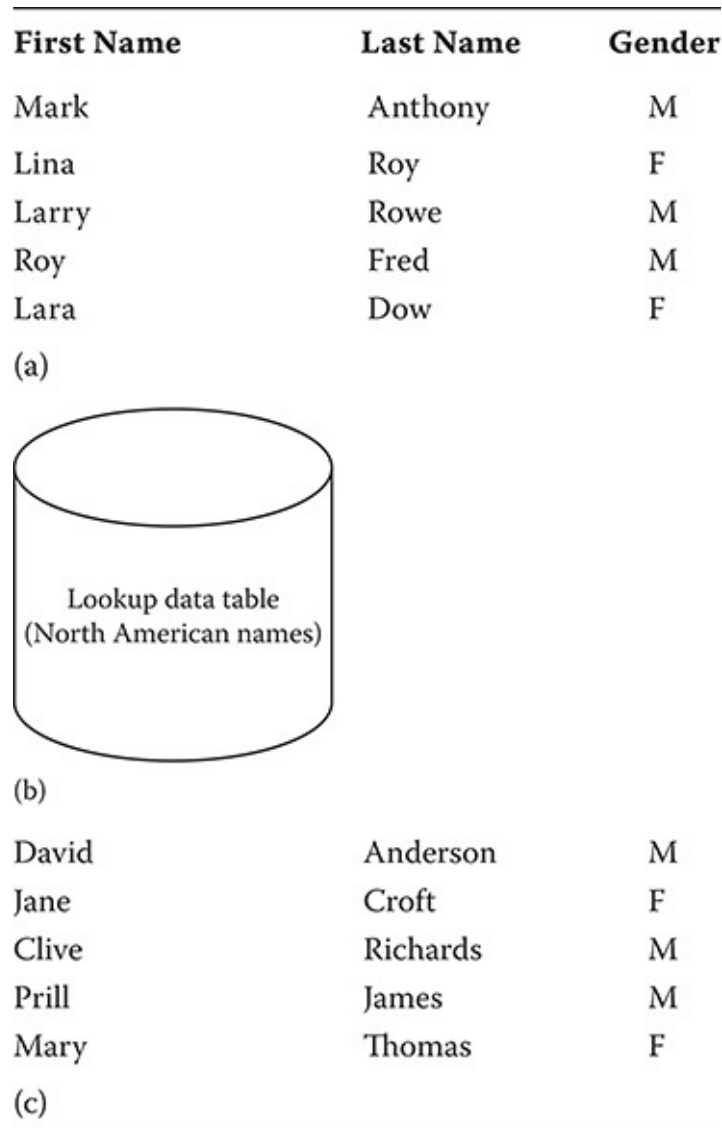


FIGURE 2.3

(a) Original data table, (b) lookup table, and (c) substituted data table.

2.3.2 Protecting Quasi-Identifiers

In the previous section, we saw that EI are primarily identifiers and names that could directly identify a record owner and hence are completely masked out. By masking EI completely, they are rendered completely unusable but provide high privacy. However, masking EI alone is not sufficient, as an adversary can still use QI to re-identify a record owner, as was demonstrated by Latanya Sweeney where she re-identified the Governor of Massachusetts by linking a health/hospital database with a voters database. This linking is called record linkage where a record from a database is linked with a record in an external data source. This is depicted in [Figure 2.4](#).

ID	First Name	Last Name	Gender	Address	DOB	Zip	Disease
—	—	—	—	—	—	—	—
12432			M	MA	21/02/1946	01880	Cancer
—	—	—	—	—	—	—	—

(a)

Voter ID	First Name	Last Name	Gender	Address	DOB	Zip
—	—	—	—	—	—	—
893423		Weld	M	MA	21/02/1946	01880
—	—	—	—	—	—	—

(b)

FIGURE 2.4

Record linkage using QIs. (a) Hospital records and (b) voters list captions.

As seen in [Figure 2.4](#), naïve masking of only EI by the hospital is not sufficient as it was linked to an external voters database and the identity of the governor was revealed and so was the disease he was suffering from. Sweeney used just three attributes—gender, date of birth, and zip code—to link records from two databases. A large population in the United States can be identified using these three attributes. Therefore, it is imperative that QI are also protected. QI attributes are categorical nominal, which means no arithmetic operations are possible on them. The finite range of these categorical nominal values needs to be considered while coming up with the anonymization approach. There are two important aspects that need to be considered while anonymizing QI:

- The analytical utility of QI needs to be preserved
- The correlation of QI attributes with sensitive data needs to be maintained to support the utility of anonymized data

So, how to anonymize QI and what methods are available? Let us consider the data [Table 2.3](#) with more dimensions.

QI are defined as those identifiers of a record owner that are also available in external data sources, such as voters database. In [Chapter 1](#), we mentioned that apart from external databases such as a voters list, a lot of information about the record owner is also available on social networking sites, which makes it very difficult to draw a boundary on QI.

2.3.2.1 Challenges in Protecting QI

Protection of QI is key to the success of any anonymization program, especially with respect to multidimensional data.

TABLE 2.3

Sample Employee Salary Table

ID	Gender	Day	Month	Year	Address	City	Zip Code	Education	Years of Experience	Salary
1	M	20	08	1968	5, K G Rd	BLR	560002	Doctorate	20	34,000
2	M	23	01	1970	1, M G Rd	BLR	560001	Postgraduate	19	24,000
3	M	15	12	1967	8, Park Rd	BLR	560033	Doctorate	22	36,000
4	F	16	02	1985	15, Canton Rd	BLR	560004	Graduate	10	14,000
5	F	03	09	1982	12, Hosur Rd	BLR	560068	Postgraduate	12	16,000
6	M	17	10	1970	6, Cubbon Rd	BLR	560001	Postgraduate	18	22,000

Identifying the boundary between QI and SD and anonymizing the QI is probably the toughest problem to solve in privacy preservation. The main challenges in anonymizing QI attributes are

- High dimensionality
- Background knowledge of the adversary
- Availability of external knowledge
- Correlation with SD to ensure utility
- Maintaining analytical utility

High dimensionality is a major challenge in anonymization of relational data [1,2]. Consider a personal loan application in a bank. It has over two hundred fields that need to be filled in by the applicant. Most of these fields happen to be QI. Such a high number of fields in QI proves a major challenge for anonymization. PPDM is exploratory in nature, and irrespective of which anonymization technique is used, there is bound to be high information loss or low utility. With high-dimensional data, it becomes difficult to define a clear boundary between QI and SD as we do not know how much background knowledge an adversary has. A good example is that you can never hide an employee database from a disgruntled human resources employee as she will have sufficient background information of the employees in the organization. Whether it is PPDM or PPTDM, high dimensionality coupled with the background knowledge of the adversary, which is not known in advance, makes anonymization design very ineffective.

With reference to the example of the personal loan application, which is highly dimensional, how can we anonymize data effectively and provision it for either PPDM or PPTDM? There are no effective anonymization methods for high dimensionality plus the complexity of adversary's background knowledge. Principle (6) offers guidance in this area.

One approach can be based on an assumption that the user has no background knowledge. This will help in identifying a boundary between QI and SD and also reduce the problem to some extent but will not eliminate it. We discuss this situation in further detail in [Chapter 4](#).

Apart from high dimensionality and background knowledge of an adversary, the amount